

Available online at www.sciencedirect.com

ScienceDirect

journal homepage: www.elsevier.com/locate/coseComputers
&
Security

Information security governance challenges and critical success factors: Systematic review



Sultan AlGhamdi*, Khin Than Win, Elena Vlahu-Gjorgievska

School of Computing and Information Technology, University of Wollongong, Wollongong, Australia

ARTICLE INFO

Article history:

Received 22 June 2020

Revised 28 August 2020

Accepted 29 August 2020

Available online 3 September 2020

Keywords:

Information security governance

ISG

Corporate governance

Security culture

Information security management system ISMS

Critical success factors CFSs

ABSTRACT

Information security is a critical aspect and plays a significant role in protecting an organization's business. Organizations are required to safeguard their information and assets to sustain their value and reputation. The systematic literature review presented in this paper aims to introduce information security governance as a comprehensive solution for alignment between information security policies and the organization's objectives. The review identified the need for developing a holistic framework for the information security governance that (1) connects the organization's objectives and its protection, (2) addresses each aspect of strategy, control, and regulation, (3) ensures compliance of procedures and guideline with policies, and (4) ensures continuous evaluation and compliance. The analysis of the literature revealed the main challenges to the adoption of an information security governance program. The review identified seven information security governance domains with 27 critical success that should be considered when developing an effective information security governance framework.

© 2020 Elsevier Ltd. All rights reserved.

1. Introduction

Information security is a critical aspect and plays a significant role in protecting an organization's business. Organizations should protect their information and assets to sustain the organization's value and reputation. Furthermore, effective management of information security requires top management support and commitment in implementing policies and procedures (Allen & Westby, 2007; Schinagl & Shahim, 2020; Von Solms, 2001). In the past, top management considered information security as a technical issue and under the information technology (IT) team's responsibility (Posthumus & Von Solms, 2004; Von Solms, 2001). Allen and Westby (2007) emphasized that the responsibilities of Information security should be distributed between an organization's departments, which requires cross-organizational interaction, collaboration, and commitment. Organizations are re-

quired to consider information security at a governance level (i.e. as a strategic issue) to achieve the organization's sustainability and its protection (Allen, 2005; Lidster & Rahman, 2018; Whitman & Mattord, 2014).

From a responsibility perspective, the literature revealed that there is a relationship between information security, corporate governance, and culture. For instance, Musa (2018) mentioned that the responsibility of information security is a part of corporate governance, and the top management must provide direction and control to protect the organization's assets and resources. While Sajko et al. (2011) stated that the concept of corporate governance could apply to information security by governing information security and its strategies. The commitment and involvement of top management are essential in developing an organizational culture and security culture, and it would motivate employees to perform their responsibilities toward

* Corresponding author.

E-mail addresses: sag264@uowmail.edu.au (S. AlGhamdi), win@uow.edu.au (K.T. Win), elenavg@uow.edu.au (E. Vlahu-Gjorgievska).
<https://doi.org/10.1016/j.cose.2020.102030>

0167-4048/© 2020 Elsevier Ltd. All rights reserved.

the organization's protection (Al-Izki and Weir, 2016). In addition, Steinbart et al. (2018) found that the support of top management can create a positive information security culture that leads to overcoming internal weaknesses of the non-compliance employees with information security policies and procedures.

Today, top management consider information security as a strategic concern that requires more attention, support, and motivation from their side. The strategic consideration of information security led to the concept called information security governance (ISG) (Nicho, 2018; Schinagl and Shahim, 2020). Different researchers defined and discussed the importance of information security governance (ISG) as a solution to achieve the organization's protection and its objectives. Posthumus and von Solms (2004a) defined ISG as a set of processes determining how to address information security at the top management level. While Sajko et al. (2011) defined ISG as a set of actions that define the engagement of the top management and other administrations in the organization. Moulton and Coles (2003) defined ISG as "managing the risks that related to information security principles include confidentiality, integrity, and availability by establishing and maintenance of the control environment, and its supporting processes and systems" (Moulton & Coles, 2003, p. 581). Furthermore, ISG enables responsibility, accountability, and risk controls at the top management level to ensure their continued commitment and support, and facilitating the alignment between the organization's objectives and its protection (Khoo et al., 2010; Mishra, 2007; Whitman & Mattord, 2014).

However, the literature has manifested that the support of the ISG programs is still experiencing some challenges. These challenges include top management support and responsibilities toward information security, as well as, comprehensive framework that consists of guidelines for implementation and description of its policies and procedures (Elachgar & Regragui, 2012; Lidster & Rahman, 2018; Munira et al., 2017; Musa, 2018; Posthumus & R. Von Solms, 2004). Numerous studies suggested that ISG can be a solution to overcome these challenges as it enables top management support and commitment (Johnston & Hale, 2009; Posthumus & Von Solms, 2004; Tu & Yuan, 2014), responsibility and accountability (Khoo et al., 2010; Musa, 2018; Rao & Ramachandran, 2007), alignment between the organization's objectives and its protection (Mahncke & Williams, 2014; Sajko et al., 2011; Tu & Yuan, 2014), establishes organizational and security culture in organizations (Al-Izki & Weir, 2016; Tu & Yuan, 2014), and improves the communication between the organization's parties (Musa, 2018).

Previous studies have taken different approaches related to establishing ISG in organizations. For instance, several studies mentioned the importance of top management support and commitment toward the successful establishment of the ISG program in organizations (Antonioni, 2018; Da Veiga & Eloff, 2007; Hina et al., 2019; Mishra, 2015; Posthumus and von Solms, 2004). While other studies focused on the culture aspect and its influence toward the implementation of ISG (Bobbert & Mulder, 2015; Corriiss, 2010; Da Veiga & Martins, 2015; Hohan et al., 2015; Thomson & Von Solms, 2005; Vinnakota, 2011; Williams, 2007). Besides that, some researchers proposed well-known frame-

works for ISG program such as COBIT and ISO27001 (Da Veiga & Eloff, 2007; De Oliveira et al., 2006; Sheikhpour & Modiri, 2012; Shivashankarappa et al., 2012; Stoll et al., 2013; Von Solms, 2005). Whereas other researchers developed an ISG framework based on different aspects identified from the literature and well-known frameworks and models (Jackson & Rahman, 2018; Manjezi & Botha, 2019; McKissack et al., 2010; Vinnakota, 2011; Williams, 2007; Wu & Saunders, 2011). Most of these studies have not comprehensively and clearly explained the processes of establishing ISG in organizations or even at least provide guidelines for its implementation.

The literature review presented in this paper attempts to provide broad dimensions for the successful establishment of the ISG by including all required aspects such as business alignment, top management support and commitment, awareness, IT efficiency, security policies development, compliance and evaluation factors identified by Tu and Yuan (2014). To achieve this, the following research question was developed:

What are the critical success factors that contribute to establishing an effective information security governance in organizations?

The rest of the paper is structured as follows. Section 2 describes the research methodology. In Section 3 the results from the literature review are presented. Section 4 reflects on the findings of the review, and Section 5 presents the conclusion and future work.

2. Research method

2.1. Study design

The systematic literature review was conducted using three large digital libraries to collect articles related to ISG. A qualitative content analysis was performed to identify challenges and critical success factors to adopt ISG in each of the included articles (Creswell, 2014). The stages of the research method are shown in Fig. 1.

2.1.1. Identification: databases and keywords

Three large digital libraries: Web of Science, IEEE Xplore, and Scopus, were used for searching articles related to ISG. These digital libraries include a large amount of information technology journals and cover all areas related to the review's focus such as strategy, governance, and information security. Furthermore, COBIT and ISO27001 have been identified as the most recommended ISG frameworks, therefore, the decision has been made to include COBIT and ISO27001 in the search. The search keywords were defined with the assistance of a professional librarian. The keywords used in the search are:

- "Information security" AND "ISO 27001"
- "Information security" AND "COBIT"
- "Information security" AND "Governance"
- "Governance" AND "COBIT"
- "Governance" AND "ISO 27001"
- "Business strategy" AND "Information Security"
- "Information Security governance" AND "compliance"

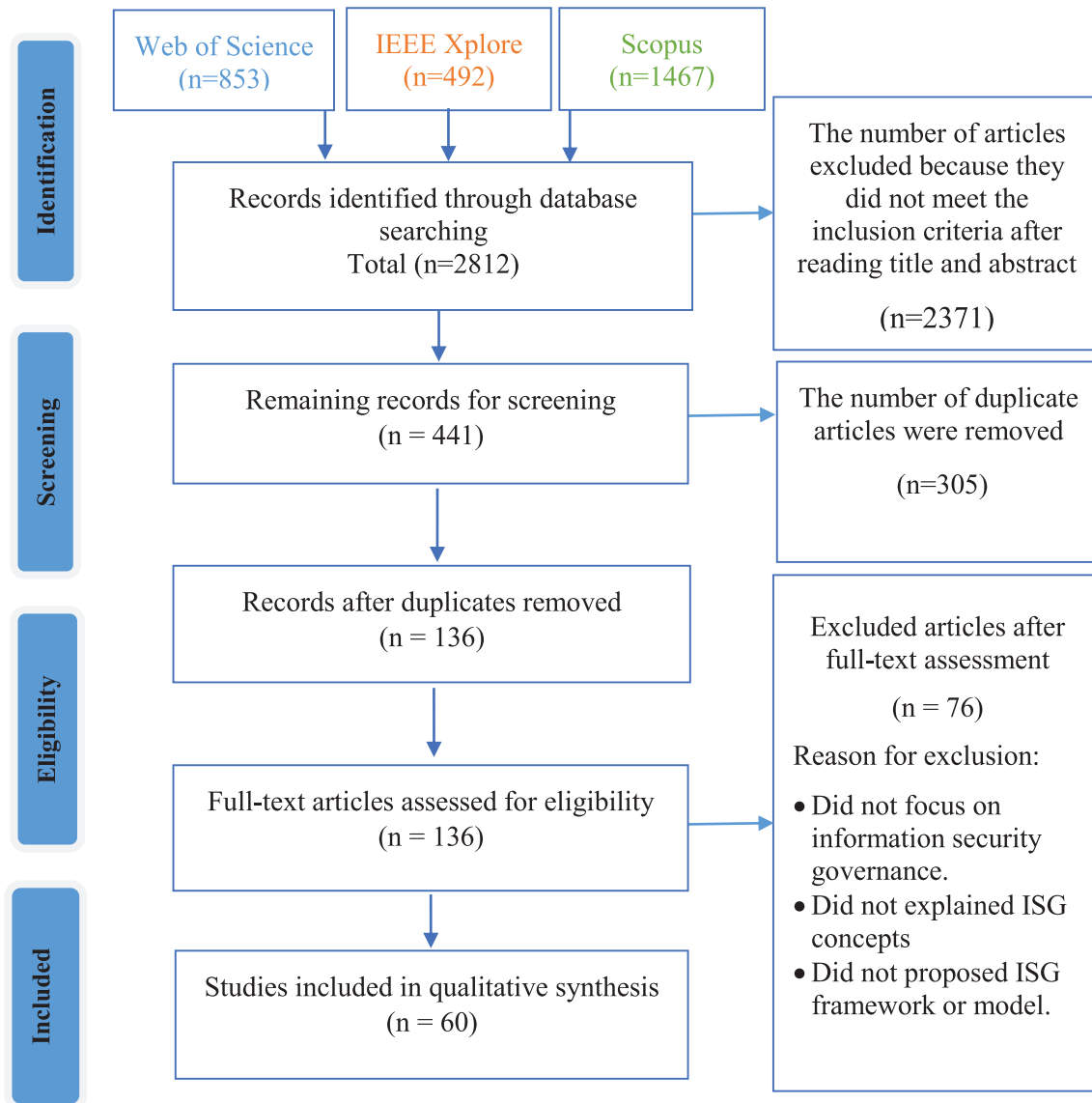


Fig. 1 – Articles selection flow diagram.

The search was conducted in March 2020, which returned a total of 2812 articles as follows:

- (1) Web of Science yielded 853 articles that were published until March 2020.
- (2) IEEE Xplore yielded 492 articles that were published until March 2020.
- (3) Scopus yielded 1467 articles that were published until March 2020.

2.1.2. Screening: title and abstract review and remove duplication

After reading the title and abstract, 2371 articles that did not meet the inclusion criteria were excluded. Then 305 duplicate articles were removed, 136 articles remained for the full-text eligibility assessment.

2.1.3. Eligibility: inclusion and exclusion criteria

The eligibility criteria included the articles that focused on information security governance - whether they were explaining the ISG concept, proposing a framework or model for ISG, and published in the English language. The articles discussing cybersecurity topics, cybersecurity frameworks, or information security frameworks focusing solely on technologies such as cloud computing and IoT were excluded in the screening process.

The aim of the inclusion and exclusion criteria was to identify the articles focused on the internal environment and governing of information security in the organization. The authors assessed 136 articles based on the inclusion and exclusion criteria. After the full-text assessment, 76 articles were excluded as not relevant to the review's goal. In the end, 60 articles were included for the final review.

2.2. Data analysis and extraction

A qualitative analysis was conducted using Nvivo (version 12) to organize, sort, and search for information through the identified articles (Creswell, 2014). The analysis process categorized the articles into different codes as follow ISG definition, ISG background, ISG frameworks, and models. Furthermore, two additional aspects have been identified through the analysis related to ISG: corporate governance, and culture. During the coding process, other aspects emerged, and all articles were categorized into the following main groups and subgroups (see Appendix G):

- ISG background group included articles discussing ISG concept in the context of ISG definitions, ISG development, ISG framework, and ISG challenges.
- Corporate governance group included articles discussing corporate governance and ISG, and related challenges.
- Culture group included articles discussing culture and ISG, and related challenges.
- ISG frameworks and models group included articles proposing well-known frameworks as well as articles proposing developed ISG framework and models.
- The critical success factors group was divided into seven groups based on their traits. Then, each group was named based on its role and main objectives. For instance, the main role of the awareness group is to promote organizational and security culture. In the end, the seven groups were inserted under a new group called ISG domains.

3. Results

Much of the literature since the 2000s emphasizes the adoption of ISG programs by organizations to provide protection that aligns with the organization's objectives and strategies. Different studies have mentioned the importance of top management support for enabling the governance of information security in terms of their responsibility and its primary role in the organization's success. Besides that, other studies have discussed the role of organizational culture and information security culture in implementing an ISG program successfully in an organization. In terms of ISG frameworks, some of the researchers have suggested using well-known frameworks for ISG such as COBIT or ISO27001, and others developed ISG frameworks based on different frameworks and models.

3.1. Corporate governance and culture

Different studies have demonstrated the relationship between corporate governance and information security. In 2002, Von Solms and Strous mention that different documents related to corporate governance or internal control clearly mentioned top management responsibility for information security. Thomson and Von Solms (2004) mention that corporate governance is related to the top management responsibility in organizations for providing direction and controls through the following four pillars: accountability, responsibility, fairness, and transparency. Corporate governance is related to organization characteristics, vision, mission, and objectives; there-

fore, the organization needs to define and plan a good strategy to achieve these objectives (De Oliveira et al., 2006). In a study conducted by Mahncke et al. (2009) mention that ISG is a major area in corporate governance that can enhance information security practice in any organization.

Further, Tan et al. (2010) argue that different kinds of literature deliberate the idea of integrating ISG as a part of corporate governance to achieve business sustainability for the organization (Gashgari et al., 2017; Maynard et al., 2018). While Kim and Kim (2015) discuss how the information security committee can be the main player for changing the top management attitude about information security and consider information security as corporate governance's responsibility. Corporate governance defines the responsibility of top management for the business value of the organization by implementing good governance that supports alignment between risk management and the organization's goals (Shivashankarappa et al., 2012). Antoniou (2018) mentions that the emphasis on corporate governance in the literature has been an obvious start point when an organization intends to initiate ISG. This is because of the characteristics of corporate governance that create the relationship between management and provides direction and control.

Culture is an essential aspect and should be considered when an organization plans to establish an information security program. Thomson and Von Solms (2005) are of the view that the corporate culture is a major aspect that can enhance the performance of the organization, determine the organization's strategy and objectives, and can be employed to influence employees' behavior toward an organization's protection. Thomson and von Solms (2004) classified corporate culture into three levels: artefacts, espoused values, and shared tacit assumptions, and argue that the top management must encourage corporate culture alongside enforcement of the organization policies. Information security must be an inherent part of an organization's culture through adopting a "Top-Down" approach and increasing awareness for all internal users in the organization (Corriss, 2010).

The transformation from the management of information security as a technical responsibility to the development of an information security culture program will bring the top management's attention and support (Williams, 2011). Hassan and Ismail (2012) believe that an information security culture can bring several benefits, such as trust, compliance with regulations and the law, and increase the organization's value. In a study conducted by De Veiga and Martins (2015), it was shown that an information security culture could be achieved by increasing information security awareness, training, monitoring, and risk assessments in the organization. For an effective information security program in the organization, the culture must be used as the main factor for protecting the organization's information and assets (Da Veiga & Martins, 2015). Defining security objectives aligned with organization strategies will lead to an effective information security culture in an organization (Hohan et al., 2015).

3.2. ISG frameworks and models

Numerous studies have proposed different ISG frameworks and models (see Appendix F). For instance,

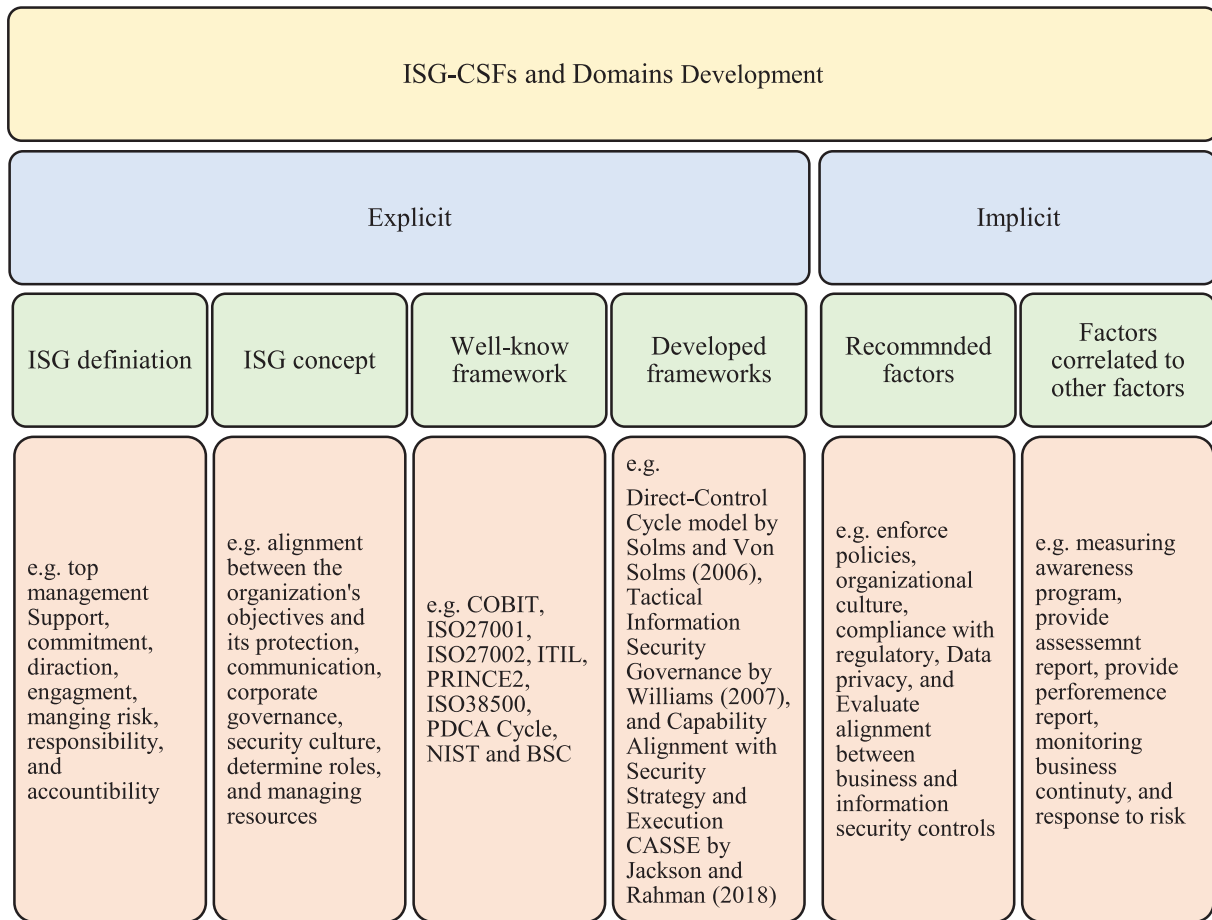


Fig. 2 – ISG- CSFs and Domains Development.

Lourinho et al. (2017) and Sheikhpour & Modiri (2012) propose COBIT and ISO 27011 as an ISG framework and combine them to provide a comprehensive ISG environment as COBIT is more suitable for governance, and ISO 27001 is more a security controls framework. In 2017, Gashgari et al. have proposed an ISG framework based on COBIT and ISO/IEC27002 standards mapping with critical success factors which can provide a positive impact on an organization's success. While other studies propose an integrated ISG framework based on three or four frameworks as follows. De Oliveira et al. (2006) propose an integrated ISG framework based on the Balanced Scorecards (BSC) for business objectives, and COBIT and ISO 17799 for alignment between the business objectives and information security practice. While Mahncke et al. (2009) find that the ISO27002, NIST 800-53, and COBIT are mostly proposed by academic papers for assessment purposes and for information security management and governance. Further, Shivashankarappa et al. (2012) propose a novel ISG framework through mapping each domain of COBIT 4.1 with the following framework, PRINCE2, ISO27001, and Information Technology Infrastructure Library (ITIL). On the other hand, Mishra (2015) mentions that ISO27002, COBIT, and ITIL are widely adopted and can be used by several organizations for

security management purposes and for security governance purposes.

In addition, different models utilized to develop ISG program that could motivate organizations to adopt security governance concepts. Back in 2006, Oliveira et al. used the COBIT Maturity Model to identify the current state of the organization and to define an action plan that supports organization objectives and requirements. Another ISG model called the Direct-Control Cycle model was introduced by Von Solms and Von Solms (2006) includes two principles. The first principle involves the strategic, tactical, and operation levels, which means that ISG involves all parties by following the top-down approach. Whereas the second principle is direct, execute, and control, which means the direct activities can be executed and controlled through measuring, monitoring, and reporting across all parties in the organization. Another assessment model for implementing ISG in an organization has been developed by Kusumah et al. (2014) through integrated COBIT5 and ITIL standards. Further, Kim and Kim (2015) propose another model based on the Competing Values Framework (CVF) that assists the top management in an organization to define information security committee responsibilities and roles. Mishra (2015) defines ISG objectives based on value-focused

thinking theory, whereas [Laksono and Supriyadi \(2016\)](#) propose a mathematical theory called the Analytic Network Process beside COBIT5 to define the priorities of an organization's objectives. Further, [Siregar et al. \(2017\)](#) suggest the use of the Process References Model from the COBIT5 framework and BSC to identify objectives, issues, and priorities in the organization. Whereas [Ahuja and Chan \(2015\)](#) propose COBIT, ISO38500, BSC, and System Security Engineering Capability Maturity Model (SSE-CMM) to mitigate ISG challenges such as alignment between information security and business objectives.

3.3. Critical success factors CSFs

The analysis of the literature revealed that different factors should be considered for an effective ISG. These factors were derived from the analysis of the 60 papers within the scope of this review and based on the following criteria (as shown in [Fig. 2](#)). The first criteria included factors that were extracted from ISG definitions, ISG concepts, recommended well-known frameworks, or developed framework for ISG. These factors have been explicitly mentioned or included by researchers in different forms, such as:

- From the definitions of ISG: top management support, commitment, direction, engagement, managing risk, responsibility, and accountability.
- From the ISG concept: alignment between the organization's objectives and its protection, communication, corporate governance, security culture, determine roles, and managing resources.
- From well-known frameworks for ISG: COBIT, ISO27001, ISO27002, ITIL, PRINCE2, ISO38500, PDCA Cycle, NIST, and BSC.
- From developed ISG frameworks: Direct-Control Cycle model by [Solms and Von Solms \(2006\)](#), Tactical Information Security Governance by [Williams \(2007\)](#), and Capability Alignment with Security Strategy and Execution CASSE by [Jackson and Rahman \(2018\)](#).

Second criteria included factors that were extracted from the context, based on the understanding and interpreting of the authors. These factors have been implicitly mentioned by researchers as follow:

- Recommended factors by researchers: enforce policies, organizational culture, compliance with regulatory, data privacy, and evaluate alignment between business and information security controls.
- Factors developed by authors that are correlated or evaluate other identified factors: measuring awareness program, provide assessment report, provide performance report, monitoring business continuity, and response to risk.

The extracted factors were used for the identification of 34 critical success factors (CSFs) based on their meaning and traits. After that, the CSFs were divided into seven domains based on their objectives and roles as following (see [appendixes A, B, and C](#)).

3.3.1. Domain 1: Responsibility and Accountability

Responsibility and accountability are considered as two important ISG components. As observed in the literature and shown in [Table 1](#), several important factors are identified under responsibility and accountability. These factors should be considered when planning to implement an ISG program in an organization. For instance, define roles and business ownerships for administrations in an organization. It means to clarify the responsibility of each administration and its role regarding implementing their missions aligned with the organization's objectives and information security policies and procedures ([Bobbert & Mulder, 2015](#); [Gashgari et al., 2017](#); [Posthumus & von Solms, 2004](#)). Besides that, each administration must identify the responsibility of each employee and continue monitoring the commitment of executing the management's directions ([Kim & Kim, 2015](#); [Mishra, 2015](#); [Rebollo et al., 2011](#); [Schinagl & Shahim, 2020](#)).

In addition, the top management should define the risk ownership and risk appetite as a part of the risk management program by identifying the responsibility of each administration to avoid potential conflict ([Gashgari et al., 2017](#); [Nicho, 2018](#); [Vinnakota, 2011](#); [Zaydi & Nasserddine, 2017](#)). The top management should provide support for ISG program and its implementation in terms of their responsibility for achieving the organization's objectives ([Manjezi & Botha, 2019](#); [Mounia & Bouchaib, 2019](#); [Schinagl & Shahim, 2020](#); [Von Solms & Von Solms, 2004](#); [Von Solms et al., 2011](#); [Von Solms & Von Solms, 2006](#)). Responsibility determines the dimensions of implementing ISG programs by defining the roles and ownership, and enforcing policies and procedures can guarantee to organize the communication process between internal and external parties in the organization ([Corriss, 2010](#); [Da Veiga & Martins, 2015](#); [Mounia & Bouchaib, 2019](#); [Ruighaver et al., 2007](#); [Schinagl & Shahim, 2020](#); [Williams, 2007](#); [Wu & Saunders, 2011](#)).

3.3.2. Domain 2: Awareness

Many studies have mentioned the importance of awareness for prompting ISG in organizations (see [Table 2](#)). Awareness is an essential factor and one of the primary components that should be included in the ISG framework. Awareness can contribute to the enhancement of knowledge of the organizational culture in order to create trust between the organization and its employees and to raise realization of security risks that the organization can face ([Alghamdi et al., 2019](#); [Da Veiga & Martins, 2015](#); [Gashgari et al., 2017](#); [Schinagl & Shahim, 2020](#); [Vinnakota, 2011](#); [Wu & Saunders, 2011](#)). Awareness should embrace all levels in the organization by following the "Top-Down" approach to guarantee that all employees are aware and informed regarding the organization's rules and security controls. Furthermore, it assists in providing protection and privacy and mitigates the risks that can impact the organization through raising the awareness of internal users to enable them and become major supporters in maintaining the organization's performance ([Bobbert & Mulder, 2015](#); [Hina et al., 2019](#); [Hohan et al., 2015](#); [Nicho, 2018](#); [Ruighaver et al., 2007](#); [Williams, 2007](#)). Further, a well-designed awareness program will assist in strengthening users' roles and interest in implementing security policies and procedures to protect an orga-

Table 1 – The extracted factors used in developing CSFs related to Responsibility and Accountability domain.

Studies	Mentioned factors	Derived		Validation	Developed factors
		Explicit	Implicit		
Ahuja and Chan (2015)	Unclear information asset ownership, Resource Management, Alignment of information security initiatives with business strategy, Alignment between Business/IT and IT security Strategies, and Risk Management	well-known framework (ISO 38500 Principles, COBIT, BSC, and SSE-CMM), and ISG concept	Recommended factors	Not specified	Define Roles and ownerships, Resource allocation, Alignment between Security and Business, and Risk Management
Antoniou (2018)	Roles and responsibilities of the leadership management IT roles, Responsibilities and roles of top management and for employees, Support ISG, supporting management structure and processes, Alignment between Security and Business, Communication, Risk Management, and Enforce policies	Developed framework, ISG concept, and ISG definition	Recommended factors	Qualitative: interviews, teleconferences	Define Roles and ownerships, Employee's Role, Support ISG, Top management and stakeholders support, Alignment between Security and Business, External/internal communication, Risk Management, and Policies enforcement
Bobbert and Mulder (2015)	Determine Roles, Accountability and responsibility at top management and stakeholders level, Determine risk appetite, Identify key information systems and business owners, Top Management Lead by good example, Top management support, Alignment strategy and approval by board, Internal communication, Risk Management, and Enforcements mechanisms.	ISG concept, and ISG definition	Recommended factors	Group Support System (GSS) Expert groups	Accountability, Responsibility, Define Roles and ownerships, Define risk ownerships, Employee's Role, support ISG, Top management and stakeholders support, Alignment between Security and Business, External/internal communication, Risk Management, and Policies enforcement
Gashgari et al. (2017)	Determine clear IS responsibility and be held accountable, Accountability, Responsibilities, Protect critical and sensitive assets, Concentrate on critical business applications, Identify critical applications & information systems, Identify data owners to assign responsibilities according to, information criticality, Resource Management, Support ISG, Support the governance objectives, top management support, On-going strategic alignment, Effective communication, and Risk Management	well-known framework (ISO/IEC 27014, 2013, and COBIT 4), ISG concept, and ISG definition	Recommended factors	Not specified	Define Roles and ownerships, Administration critical business, Employee's Role, Resource allocation, Support ISG, Top management and stakeholders support, Alignment between Security and Business, External/internal communication, Risk Management, and Policies enforcement
Mishra (2015)	Enable responsibility and accountability in roles, Provide clarity in roles and ownership of decisions, Promote transparency in roles, Ensure data criticality, Identify data owners, Maximize resource allocation, Support ISG, Ensure visible top management, Maximize management commitment, Ensure alignment with organizational values, Ensure communication, Risk management, Establish clarity in policies and	ISG concept, and ISG definition	Recommended factors	Qualitative: interviews	Define Roles and ownerships, Define risk ownerships, Employee's Role, Resource allocation, ISG support, Top management and stakeholders support, Alignment between Security and Business, External/internal communication, Risk management, and Policies enforcement

Table 1 (continued)

Studies	Mentioned factors	Derived		Validation	Developed factors
		Explicit	Implicit		
Patnayakuni and Patnayakuni (2014)	Shared responsibility and accountability, Clear ownership, Accountability and responsibility for the protection of valuable information assets, Shared responsibility for information security, Teams and liaison roles, Top management needs to pay attention, Communication, Define formal processes for risk analysis, and Risk management.	Developed framework (conceptual framework), and ISG concept	Recommended factors	Not specified	Accountability, Responsibility, Define Roles and ownerships, Define risk ownerships, Employee's Role, Top management and stakeholders support, External/internal communication, and Risk management
Posthumus and von Solms (2004b)	Identify the key role players, Accountability and responsibility, Top management support, Communication, Risk management, and Policies enforcement	Developed framework, ISG concept, and ISG definition	Recommended factors	Not specified	Accountability, Responsibility, Define Roles and ownerships, Top management and stakeholders support, External/internal communication, Risk management, and Policies enforcement
Schinagl and Shahim (2020)	Security governance focuses on setting the responsibilities, Legal responsibility, Top management's primary role in security, Roles and ownership, IS risk, Resources are used responsibly, ISG support, Management commitment, Alignment between Security and Business, Communication, Risk management, and Enforce policies	ISG concept, and ISG definition	Recommended factors	Not specified	Accountability, Responsibility, Define Roles and ownerships, Employee's Role, Resource allocation, ISG support, Top management and stakeholders support, Alignment between Security and Business, External/internal communication, Risk management, Policies enforcement
Sheikhpour and Modiri (2012)	Responsibility for assets, Operational procedures and responsibilities, user responsibilities, enabling responsibilities and accountability, Business requirement for access control, Ensure systems security, Manage IT human resources, Procure IT resources, Alignment between Security and Business, Communications and operations management, Assess and manage IT risks, and Policies enforcement	well-known framework (ISO/IEC 27001, and COBIT), and ISG concept	Recommended factors	Not specified	Accountability, Responsibility, Define Roles and ownerships, Administration critical business, Define risk ownerships, Employee's Role, Resource allocation, Alignment between Security and Business, External/internal communication, Risk management, Policies enforcement
Shivashankarappa et al. (2012)	Misunderstanding role in the enterprise, accountability, Definition business functional and technical requirements, User account management, Prepare a Risk Register, Manage Human Resources, Procure IT Resources, Business-IT alignment, Communicate, Management Aims and Direction, Prepare the communication management strategy, Enterprise IT risk and control, Prepare the Risk Management Strategy	well-known framework (COBIT 4.1, PRINCE 2, ITIL V3, and ISO/IEC 27002:2005), and ISG concept	Recommended factors	Not specified	Accountability, Responsibility, Define Roles and ownerships, Administration critical business, Define risk ownerships, Employee's Role, Resource allocation, Alignment between Security and Business, External/internal communication, Risk management

(continued on next page)

Table 1 (continued)

Studies	Mentioned factors	Derived		Validation	Developed factors
		Explicit	Implicit		
Tan et al. (2017)	Define roles and ownership, Risk ownerships, designating roles and responsibilities, Allocating resources, Top management support, Communication, and Risk management	ISG concept	Recommended factors	Case study	Define Roles and ownerships, Employee's Role, Resource allocation, Top management and stakeholders support, External/internal communication, Risk management
Vinnakota (2011)	Roles & Responsibilities, Defines the roles of members, provide assignment of responsibility, Leaders are Accountable, Top management responsibilities, Management commitment and support, Communication, and Policies enforcement	Developed framework (InfoGov model, and GovInfoS model), ISG concept, and ISG definition	Recommended factors	Quantitative: questionnaire, and qualitative tools developed	Define Roles and ownerships, Employee's Role, ISG support, Top management and stakeholders support, External/internal communication, Policies enforcement
Oliveira et al. (2006)	Defining responsibilities and related duties, Create an executive committee to define directives and support tactical decisions about IS responsibilities, support a continuous process of security management, support governance requirements, Top management support, Alignment between information security and business objectives, Continuous improvement of communication processes, Define risk processes, Risk management, Implement policies, and Policies enforcement	well-known framework (Balanced Scorecard (BSC) - COBIT, and ISO/IEC 17799), ISG concept, and ISG definition	Recommended factors	Not specified	Administration critical business, Employee's Role, ISG support, Top management and stakeholders support, Alignment between Security and Business, External/internal communication, risk management, and Policies enforcement
Horne et al. (2017)	Boardroom accountability, Employees roles and responsibilities, Top management support, Alignment between Security and Business, Communication, Risk management, Policies enforcement	ISG concept	Recommended factors	Not specified	Employee's Role, ISG support, Top management and stakeholders support, Alignment between Security and Business, External/internal communication, Risk management, and Policies enforcement
Kim and Kim (2015)	Clear role and responsibility, Define respective accountability, Top management support and commitment	Developed framework (Competing values framework), and ISG concept	Recommended factors	Not specified	Employee's Role, Top management, and stakeholders support
Maynard et al. (2018)	Lack of accountability, designating roles and responsibilities, ISG support, Top management support, and Ensure compliance with security policies and standards	ISG concept	Recommended factors	Case study: interviews	Employee's Role, ISG support, Top management and stakeholders support, and Policies enforcement
Nicho (2018)	Decide on roles and responsibilities, ISG support, Steering committee, Management buy-in, Alignment with business strategies, and Policies enforcement	Developed framework (PDCA cycle), ISG concept, and ISG definition	Recommended factors	Qualitative: expert interviews	Employee's Role, ISG support, Top management and stakeholders support, Alignment between Security and Business, and Policies enforcement

(continued on next page)

Table 1 (continued)

Studies	Mentioned factors	Derived		Validation	Developed factors
		Explicit	Implicit		
Rebollo et al. (2011)	Control and Accountability, Every person responsibility, Roles and Responsibilities, ISG support, Top management support, Strategic Alignment, Risk management, and Policies enforcement	ISG concept, and ISG definition	Recommended factors	Not specified	Employee's Role, ISG support, Top management and stakeholders support, Alignment between Security and Business, Risk management, and Policies enforcement
Rubino et al. (2017)	Assignment of authority and responsibility, Management responsibilities, Individuals accountable for their responsibilities, Definition role and responsibility, Assign appropriate levels of authority and responsibility, Human resources policies and practices, Top management support, Communication, Risk management, and Policies enforcement	well-known framework (COBIT)	Recommended factors	Not specified	Employee's Role, Resource allocation, Top management and stakeholders support, External/internal communication, Risk management, and Policies enforcement
Saunders and Yu (2011)	Roles and responsibilities, Assigning security responsibilities and accountabilities, Insufficiency in human and Technical resources for security, Top management support, and Policies enforcement	ISG concept	Recommended factors	Not specified	Employee's Role, Resource allocation, Top management and stakeholders support, and Policies enforcement
Shojaie et al. (2015)	Employees' responsibilities, Management role, Information security roles and responsibilities, Human resource management, Policies enforcement	well-known framework (ISO27001)	Recommended factors	Not specified	Employee's Role, Resource allocation, and Policies enforcement
Thomson and von Solms (2005)	Management accountable and responsible, Employee's Role, ISG support, Top management support, and Policies enforcement	ISG concept	Recommended factors	Not specified	Employee's Role, ISG support, Top management and stakeholders support, and Policies enforcement
Veiga and Eloff (2007)	User responsibilities, Defined roles and responsibilities, Asset management (responsibility and classification), Support for information security, Establishing executive sponsorship, Management commitment and support, and Policies enforcement	Well-known framework (ISO177995, ISO27001, Capability Maturity Model, Information security Architecture (ISA), Protect), and ISG concept	Recommended factors	Not specified	Employee's Role, ISG support, Top management and stakeholders support, Policies enforcement
Von Solms and von Solms (2004)	Information security is a corporate governance responsibility, Accountability shared by all employees, ISG support, Top management support, and Policies enforcement	ISG concept	Recommended factors	Not specified	Employee's Role, ISG support, Top management and stakeholders support, and Policies enforcement
Williams (2007)	No clear delineation of responsibility, Identify Roles and responsibilities, Policy implementation	Developed framework (Tactical Information Governance Security Model (TIGS)), and ISG concept	Recommended factors	Pilot study, interviews	Employee's Role, and Policies enforcement

(continued on next page)

Table 1 (continued)

Studies	Mentioned factors	Derived		Validation	Developed factors
		Explicit	Implicit		
Haufe et al. (2016)	Resource management process, Information security governance process, Alignment of the ISMS, Communication process, and Information security risk treatment process	Well-known framework (ISO27001, ITIL, COBIT)	Recommended factors	Pilot implementation	Resource allocation, Support ISG, Alignment between Security and Business, and External/internal communication
Jackson and Rahman (2018)	Resource Management, Support ISG, strategic alignment, and Risk management	Developed framework (Capabilities Alignment with Security Strategy and Execution (CASSE) Platform)	Recommended factors	Not specified	Resource allocation, Alignment between Security and Business, and Risk management
Modaresnezhad and Palvia (2013)	Resource allocation, Support ISG, Top management and stakeholders support, Alignment between Security and Business, Internal/External Communication, Risk management, enforcing IT security and privacy policies	ISG concept	Recommended factors	Qualitative: interviews	Resource allocation, Support ISG, Top management and stakeholders support, Alignment between Security and Business, Internal/External Communication, Risk management, and Policies enforcement
Coertze and Von Solms (2013)	Support ISG, management and leadership commitment, Top management direction, and Enforcement mechanisms	Developed framework (Information security governance model), ISG concept, and ISG definition	Recommended factors	Not specified	Support ISG, Top management and stakeholders support, Policies enforcement
Corriss (2010)	Support ISG, Top management support, and Enforcement of the policy	ISG concept	Recommended factors	Not specified	Support ISG, Top management and stakeholders support, Enforcement policies
Manjezi and Botha (2019)	Support ISG, and Top management support	Well-known framework (Direct Control Cycle model), and ISG concept	Recommended factors	Not specified	Support ISG, and Top management and stakeholders support
Mounia and Bouchaib (2019)	Support ISG, Alignment between Security and Business, Risk management, and Policies enforcement	Well-known framework (ISO 38500, ITIL, ISO27001), ISG concept, and ISG definition	Recommended factors	Not specified	Support ISG, Alignment between Security and Business, External/internal communication, Risk management, and Policies enforcement
Ohki et al. (2009)	Support ISG, Management commitment, Communication, and Risk management	Developed framework (Information security governance framework), ISG concept, and ISG definition	Recommended factors	Not specified	Support ISG, Top management and stakeholders support, External/internal communication, and Risk management
Rastogi and von Solms (2004)	Support ISG, Top management support, Alignment between Security and Business	ISG definition	Recommended factors	Not specified	Support ISG, Top management and stakeholders support, and Alignment between Security and Business

(continued on next page)

Table 1 (continued)

Studies	Mentioned factors	Derived		Validation	Developed factors
		Explicit	Implicit		
Tan et al. (2010)	Support ISG, and Policies enforcement	Developed framework (Security governance framework), and ISG concept	Recommended factors	Case study	Support ISG, and Policies enforcement
Von Solms and Strous (2002)	Support ISG, and Top management support	ISG definition	Recommended factors	Not specified	Support ISG, and Top management and stakeholders support
Von Solms and von Solms (2006)	Support ISG, Top management support, Compliance enforcement	Well-known framework (ISO 38500, ITIL, ISO27001), ISG concept, and ISG definition	Recommended factors	Not specified	Support ISG, Top management and stakeholders support, and Policies enforcement
Von Solms et al. (2011)	Support ISG, Strategic level management directives, Top management support, Alignment between Security and Business, Policies enforcement	Developed framework (A comprehensive Information Security Policy Architecture), and ISG concept	Recommended factors	Not specified	Support ISG, Top management and stakeholders support, Alignment between Security and Business, Policies enforcement
Hina et al. (2019)	Commitment of top management, top management support, Communication, Provision of Policy, Information Security Policies Compliance	ISG concept	Recommended factors	Not specified	Top management and stakeholders support, External/internal communication, and Policies enforcement
Hohan et al. (2015)	Commitment of top management, Top management support, Proactive alignment of security posture	Developed framework (Self-assessment based on the European Foundation for Quality Management (EFQM) Business Excellence Model)	Recommended factors	Not specified	Top management and stakeholders support, Alignment between Security and Business
Thomson and von Solms (2004)	Top management support, and Policies enforcement	ISG concept	Recommended factors	Not specified	Top management and stakeholders support, and Policies enforcement
Da Veiga and Martins (2015)	Top management support, Effective communication, Policies enforcement	Developed framework (information security culture assessment (ISCA) Model)	Recommended factors	Quantitative: Survey	Top management and stakeholders support, External/internal, Communication, and Policies enforcement

nization's assets and information (Nicho, 2018; Rebollo et al., 2011; Thomson & Von Solms, 2005).

3.3.3. Domain 3: Compliance

Compliance with laws and regulations is vital, and one of the key elements that ensure successful and sustainable ISG in organizations. Compliance represents a balance between the organization's objectives and information security policies and procedures to provide the maximum level of protection for the organization (Antoniou, 2018; Gashgari et al., 2017; Hina et al., 2019; Horne et al., 2017; Nicho, 2018; Zaydi & Nasserddine, 2017). Even though compliance considers as a challenge for organizations, it can enhance the reputation of the organization and increase the top management's con-

fidence in the organization (Coertze & Von Solms, 2013). As shown in Table 3, many studies have discussed the importance of the compliance culture in implementing ISG programs in organizations. The compliance is not just for internal users in the organization, it extends including partners, vendors or any third-party that deal with the organization to ensure data rights and privacy of the organization (Alghamdi et al., 2019; Antoniou, 2018; Bobbert & Mulder, 2015; Da Veiga & Martins, 2015; Haufe et al., 2016). Compliance should start from the top level in the organization to reflect a positive image for the rest of the internal users regarding its importance. As a result, the internal users will start to contribute and follow the compliance process and respect it (Rastogi & von Solms, 2004).

Table 2 – The extracted factors used in developing CSFs related to Awareness domain.

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Bobbert and Mulder (2015)	Awareness, and Organisational culture	ISG concept, and ISG definition	Recommended factors	Group Support System (GSS) Expert groups	Awareness, and Organisational culture
Gashgari et al. (2017)	Effective IS awareness and training	well-known framework (ISO/IEC 27014, 2013, and COBIT 4), ISG concept, and ISG definition	Recommended factors	Not specified	Awareness, Security culture
Mishra (2015)	Security awareness	ISG concept, and ISG definition	Recommended factors	Qualitative: interviews	Awareness, Security culture
Schinagl and Shahim (2020)	Organisational culture, Security culture	ISG concept, and ISG definition	Recommended factors	Not specified	Awareness, Organisational culture, and Security culture
Vinnakota (2011)	Ensures employees are informed and aware about information security risk, Culture, and full user awareness	Developed framework (InfoGov model, and GovInfoS model), ISG concept, and ISG definition	Recommended factors	Quantitative: questionnaire, and qualitative tools developed	Awareness, Organisational culture, Security culture
Oliveira et al. (2006)	Awareness, and Organisational culture	well-known framework (Balanced Scorecard (BSC) - COBIT, and ISO/IEC 17799), ISG concept, and ISG definition	Recommended factors	Not specified	Awareness, and Organisational culture
Nicho (2018)	Training (technical and awareness) for all IT and non-IT staff	Developed framework (PDCA cycle), ISG concept, and ISG definition	Recommended factors	Qualitative: expert interviews	Awareness, Security culture
Rebollo et al. (2011)	Security risk awareness	ISG concept, and ISG definition	Recommended factors	Not specified	Awareness, Security culture
Saunders and Yu (2011)	Security culture	ISG concept	Recommended factors	Not specified	Awareness, Security culture
Shojaie et al. (2015)	Information security awareness, education and training	well-known framework (ISO27001)	Recommended factors	Not specified	Awareness, Security culture
Thomson and von Solms (2005)	Organisational culture, and Security culture	ISG concept	Recommended factors	Not specified	Awareness, Organisational culture, and Security culture
Williams (2007)	Awareness of Ethical and Professional Responsibilities, and Increase awareness of security	Developed framework (Tactical Information Governance Security Model (TIGS)), and ISG concept	Recommended factors	Pilot study, interviews	Awareness, Organisational culture, and Security culture
Haufe et al. (2016)	Ensure necessary awareness	Well-known framework (ISO27001, ITIL, COBIT)	Recommended factors	Pilot implementation	Awareness, Security culture
Jackson and Rahman (2018)	Process to assure necessary awareness and competence	Developed framework (Capabilities Alignment with Security Strategy and Execution (CASSE) Platform)	Recommended factors	Not specified	Awareness, Security culture
Modaresnezhad and Palvia (2013)	Awareness, organizational and security culture	ISG concept	Recommended factors	Qualitative: interviews	Awareness, Organisational culture, and Security culture
Alghamdi et al. (2019)	Set up an awareness program	ISG concept	Recommended factors	Not specified	Awareness, Organisational culture, and Security culture

(continued on next page)

Table 2 (continued)

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Corriss (2010)	Awareness, Organisational culture, and Security culture	ISG concept	Recommended factors	Not specified	Awareness, Organisational culture, and Security culture
Hina et al. (2019)	Awareness of isps	ISG concept	Recommended factors	Not specified	Awareness, Security culture
Hohan et al. (2015)	Organisation culture, and Security culture	Developed framework (Self-assessment based on the European Foundation for Quality Management (EFQM) Business Excellence Model)	Recommended factors	Not specified	Awareness, Organisational culture, and Security culture
Da Veiga and Martins (2015)	Information security culture, and User Awareness	Developed framework (information security culture assessment (ISCA) Model)	Recommended factors	Quantitative: Survey	Awareness, Security culture
Ruighaver et al. (2007)	Security culture	ISG concept	Recommended factors	Not specified	Awareness, Security culture
Hassan et al. (2012)	Security culture, Information Security Awareness	Developed framework (Conceptual model), and ISG concept	Recommended factors	Not specified	Awareness, Security culture
Williams (2011)	Security awareness culture	ISG concept	Recommended factors	Not specified	Awareness, Security culture

3.3.4. Domain 4: Assessment (Auditing)

The best method to ensure the ISG program is working effectively and sufficiently is through performing assessment (i.e. auditing). The assessment process assists in identifying the gaps between the organization's objectives and security controls, and it can detect the risks that can occur because of misuse or inadequate policies and procedures. As shown in Table 4, the assessment is mentioned by different researchers for evaluating the compliance with the laws and regulations, and the organization's security and competency of a business continuity plan on a regular basis (Alghamdi et al., 2019; Bobbert & Mulder, 2015; Corriss, 2010; Gashgari et al., 2017; Haufe et al., 2016; Hina et al., 2019; Mounia & Bouchaib, 2019; Williams, 2011). The risk assessment program has different forms as identified in the literature such as external consultation for the strategic part and external penetration testing for the technical part to eliminate any biases in the assessment report (De Oliveira et al., 2006; Nicho, 2018; Ohki et al., 2009; Posthumus & von Solms, 2004; Shivashankarappa et al., 2012; Wu & Saunders, 2011). Auditors can identify risks that can appear and suggest improvements and proactive actions to avoid any negative impacts on the organization (Corriss, 2010; Haufe et al., 2016; Williams, 2011). Organizations should per-

form an assessment program in order to propose recommendations and prediction for a future state and improvement of ISG program for improvement purposes (Mishra, 2015; Stoll et al., 2013; Vinnakota, 2011; Zaydi & Nasserddine, 2017).

3.3.5. Domain 5: Measurement

Performance and changes in an organization are continual and are required to track to evaluate whether the ISG principles, policies, and procedures are working according to pre-defined indicators and criteria. As observed in the literature and shown in Table 5, many studies have suggested different methods and techniques for measuring the maturity level of the organization to maintain the implementation of ISG programs. The measures include measurement of the employees' awareness level and culture, and the commitment to performing the responsibilities and duties inside the organization (Da Veiga & Eloff, 2007; De Oliveira et al., 2006; Hina et al., 2019; Hohan et al., 2015; Mishra, 2015; Modaresnezhad & Palvia, 2013; Nicho, 2018; Stoll et al., 2013). The measurement indicators are considered the best method to achieve top management commitment and support for the ISG program and to reflect the harmonization between the organization's strategies and information security policies and proce-

Table 3 – The extracted factors used in developing CSFs related to Compliance domain

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Ahuja and Chan (2015)	Ensure regulatory compliance	well-known framework (ISO 38500 Principles, COBIT, BSC, and SSE-CMM), and ISG concept	Recommended factors	Not specified	Compliance with law and regulatory
Antoniou (2018)	Legal compliance and regulations	Developed framework, ISG concept, ISG definition	Recommended factors	Qualitative: interviews, teleconferences	Compliance with law and regulatory
Bobbert and Mulder (2015)	Compliance with the law and relevant standards.	ISG concept, and ISG definition	Recommended factors	Group Support System (GSS) Expert groups	Compliance with law and regulatory
Gashgari et al. (2017)	Ensure IS policies and practices comply with law & regulations and relevant requirements, and Protect classified information	well-known framework (ISO/IEC 27014, 2013, and COBIT 4), ISG concept, and ISG definition	Recommended factors	Not specified	Compliance with law and regulatory, and Data copyrights and privacy
Mishra (2015)	Ensuring regulatory compliance, and Ensure data criticality	ISG concept, and ISG definition	Recommended factors	Qualitative: interviews	Compliance with law and regulatory, and Data copyrights and privacy
Patnayakuni and Patnayakuni (2014)	Compliance with law and regulatory	Developed framework (conceptual framework), and ISG concept	Recommended factors	Not specified	Compliance with law and regulatory
Schinagl and Shahim (2020)	Compliance with law and regulatory	ISG concept, and ISG definition	Recommended factors	Not specified	Compliance with law and regulatory
Sheikhpour and Modiri (2012)	Compliance with legal requirements, and Compliance with security policies, standards and technical compliance	well-known framework (ISO/IEC 27001, and COBIT), and ISG concept	Recommended factors	Not specified	Compliance with law and regulatory
Shivashankarappa et al. (2012)	Ensure Compliance with External Requirement, Compliance with security policies and standards, and Data classification scheme	well-known framework (COBIT 4.1, PRINCE 2, ITIL V3, and ISO/IEC 27002:2005), and ISG concept	Recommended factors	Not specified	Compliance with law and regulatory, and Data copyrights and privacy
Tan et al. (2017)	Compliance with law and regulatory	ISG concept	Recommended factors	Case study	Compliance with law and regulatory
Vinnakota (2011)	Compliance with law and regulatory, and protection of all information	Developed framework (InfoGov model, and GovInfoS model), ISG concept, and ISG definition	Recommended factors	Quantitative: questionnaire, and qualitative tools developed	Compliance with law and regulatory, and Data copyrights and privacy
Horne et al. (2017)	Regulatory compliance, Security functions and outsourced contractors need to adhere to the security policies and strategy	ISG concept	Recommended factors	Not specified	Compliance with law and regulatory, and third-party auditing
Maynard et al. (2018)	Ensure compliance of systems with security policies and standards	ISG concept	Recommended factors	Case study: interviews	Compliance with law and regulatory
Nicho (2018)	Compliance with relevant security standards, policies and programs	Developed framework (PDCA cycle), ISG concept, and ISG definition	Recommended factors	Qualitative: expert interviews	Compliance with law and regulatory
Rebollo et al. (2011)	Compliance with law and regulatory	ISG concept, and ISG definition	Recommended factors	Not specified	Compliance with law and regulatory
Veiga and Eloff (2007)	Legal & Regulatory, and Compliance with legal and regulatory	Well-known framework (ISO177995, ISO27001, Capability Maturity Model, Information security Architecture (ISA), Protect), and ISG concept	Recommended factors	Not specified	Compliance with law and regulatory

Table 3 (continued)

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Haufe et al. (2016)	Process to control outsourced services	Well-known framework (ISO27001, ITIL, COBIT)	Recommended factors	Pilot implementation	Third-party engagement
Modaresnezhad and Palvia (2013)	Compliance with Law and regulatory, and privacy strategy	ISG concept	Recommended factors	Qualitative: interviews	Compliance with Law and regulatory, and Data copyrights and privacy
Zaydi and Nasserddine (2017)	Compliance with law and regulation	Developed framework (Governance, Risk, Compliance and Technology Intelligence GRC-IT), and ISG concept	Recommended factors	Not specified	Compliance with law and regulation
Alghamdi et al. (2019)	Assign the regulatory privacy, laws, policies, standards, external influences, and constraints, manage the third-party engagement, and Assign the regulatory privacy	ISG concept	Recommended factors	Not specified	Compliance with law and regulatory, 3 rd party engagement, and Data copyrights and privacy
Coertze and Von Solms (2013)	Compliance with law and regulatory	Developed framework (Information security governance model), ISG concept, and ISG definition	Recommended factors	Not specified	Compliance with law and regulatory
Corriss (2010)	Compliance, and Adherence to the policies	ISG concept	Recommended factors	Not specified	Compliance with law and regulatory
Rastogi and von Solms (2004)	Compliance with applicable laws and regulations	ISG definition	Recommended factors	Not specified	Compliance with law and regulatory
Hina et al. (2019)	Compliance with ISP, Third party engagement, and Data privacy	ISG concept	Recommended factors	Not specified	Compliance with law and regulatory, 3 rd party engagement, and Data copyrights and privacy
Hohan et al. (2015)	Ensure compliance	Developed framework (Self-assessment based on the European Foundation for Quality Management (EFQM) Business Excellence Model)	Recommended factors	Not specified	Compliance with law and regulatory
Da Veiga and Martins (2015)	Compliance with policies and regulatory requirements	Developed framework (information security culture assessment (ISCA) Model)	Recommended factors	Quantitative: Survey	Compliance with law and regulatory
Mckissack et al. (2010)	Regulatory compliance	Developed framework (Conceptual model for security assessment), and ISG concept	Recommended factors	Not specified	Compliance with law and regulatory
Siregar et al. (2017)	Compliance with external laws and regulations	Well-known framework (COBIT)	Recommended factors	Not specified	Compliance with law and regulatory

dures (Corriss, 2010; Jackson & Rahman, 2018; McKissack et al., 2010; Mishra, 2015; Von Solms & Von Solms, 2006). Besides that, other studies have discussed the importance of measuring the internal user awareness to identify their maturity level toward complying with security policies and proce-

dures (Rebollo et al., 2011; Ruighaver et al., 2007; Sheikhpour & Modiri, 2012; Shivashankarappa et al., 2012; Shojaie et al., 2015; Thomson & Von Solms, 2004; Vinnakota, 2011).

Table 4 – The extracted factors used in developing CSFs related to Assessment (Auditing) domain.

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Bobbert and Mulder (2015)	Regularly review processes and procedures, Evaluate organization security architecture, Evaluate business continuity and recover plan, and independent audit.	ISG concept, and ISG definition	Recommended factors	Group Support System (GSS) Expert groups	Evaluate policies and procedure, Evaluate organization security architecture, Evaluate business continuity and recover plan, and Third-party auditing
Gashgari et al. (2017)	On-going strategic alignment, Ensure IS policies, Evaluate current & future information threats, Effective business continuity/disaster recovery plan	Well-known framework (ISO/IEC 27014, 2013, and COBIT 4), ISG concept, and ISG definition	Recommended factors	Not specified	Evaluate alignment between security controls and business, Evaluate policies and procedure, Evaluate organization security architecture, Evaluate business continuity and recover plan
Mishra (2015)	Ensure business processes are better protected, Provide an end-to-end view of the business process and manage changes, Understand the organizational context of particular controls, Change in roles should be reflected in subsequent controls, Ensure continuous improvements in controls, IT architecture review, external audits	ISG concept, and ISG definition	Recommended factors	Qualitative: interviews	Evaluate alignment between security controls and business, Evaluate policies and procedures, Evaluate organization security architecture, Third party auditing
Patnayakuni and Patnayakuni (2014)	Evaluate policies and procedure, Security design, and business continuity	Developed framework (conceptual framework), and ISG concept	Recommended factors	Not specified	Evaluate policies and procedure, Evaluate organization security architecture, and Evaluate business continuity and recover plan
Posthumus and von Solms (2004b)	Audit committee conducting performance reviews and internal control	Developed framework, ISG concept, and ISG definition	Recommended factors	Not specified	Evaluate policies and procedure
Shivashankarappa et al. (2012)	Evaluate Internal Control, Assurance of internal control, and Review of the information security policy	Well-known framework (ISO/IEC 27001, and COBIT), and ISG concept	Recommended factors	Not specified	Evaluate policies and procedures
Tan et al. (2017)	Evaluate policies and procedures, evaluate organization security architecture, and Evaluate business continuity and recover plan	ISG concept	Recommended factors	Case study	Evaluate policies and procedures, Evaluate organization security architecture, and Evaluate business continuity and recover plan
Vinnakota (2011)	Maintaining security strategy are aligned with and support business objectives, Reviewed and Audited, Evaluate policies and procedures	Developed framework (InfoGov model, and GovInfoS model), ISG concept, and ISG definition	Recommended factors	Quantitative: questionnaire, and qualitative tools developed	Evaluate alignment between security controls and business, and Evaluate policies and procedures

(continued on next page)

Table 4 (continued)

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Oliveira et al. (2006)	Realign processes to the business objectives, processes Evaluation based on IS and business objectives, and Validate the implementation of controls	Well-known framework (Balanced Scorecard (BSC) - COBIT, and ISO/IEC 17799), ISG concept, and ISG definition	Recommended factors	Not specified	Evaluate alignment between security controls and business, and Evaluate policies and procedures
Nicho (2018)	Evaluate alignment between security controls and business, evaluate effectiveness of Controls, Evaluate organization security architecture, and external audits	Developed framework (PDCA cycle), ISG concept, and ISG definition	Recommended factors	Qualitative: expert interviews	Evaluate alignment between security controls and business, Evaluate policies and procedures, Evaluate organization security architecture, and Third party auditing
Von Solms and von Solms (2004)	Auditing dimension	ISG concept	Recommended factors	Not specified	Third party auditing
Williams (2007)	Assessment process, and Audit	Developed framework (Tactical Information Governance Security Model (TIGS)), and ISG concept	Recommended factors	Pilot study, interviews	Evaluate policies and procedures, and Third-party auditing
Haufe et al. (2016)	Internal audit of information security controls, and service provider auditing	Well-known framework (ISO27001, ITIL, COBIT)	Recommended factors	Pilot implementation	Evaluate policies and procedure, and Third-party auditing
Jackson and Rahman (2018)	Evaluate alignment between security controls and business	Developed framework (Capabilities Alignment with Security Strategy and Execution (CASSE) Platform)	Recommended factors	Not specified	Evaluate alignment between security controls and business
Modaresnezhad and Palvia (2013)	Evaluate policies and procedure, and Third-party auditing	ISG concept	Recommended factors	Qualitative: interviews	Evaluate policies and procedure, and Third-party auditing
Alghamdi et al. (2019)	Analyze security changes, Security requirements evaluation, Identify appropriate security requirements, Unify security requirement with systems engineering models, Study the change of security requirements, Analyses former implementation security strategies	ISG concept	Recommended factors	Not specified	Evaluate alignment between security controls and business, Evaluate policies and procedure, and Evaluate organization security architecture
Corriss (2010)	Security must be aligned with the organization's goals, and external auditors	ISG concept	Recommended factors	Not specified	Evaluate alignment between security controls and business, and Third-party auditing
Mounia and Bouchaib (2019)	Evaluate alignment between security controls and business, Evaluate process, and Evaluate business continuity and recover plan	Well-known framework (ISO 38500, ITIL, ISO27001), ISG concept, and ISG definition	Recommended factors	Not specified	Evaluate alignment between security controls and business, Evaluate policies and procedures, and Evaluate business continuity and recover plan

(continued on next page)

Table 4 (continued)

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Ohki et al. (2009)	Evaluate alignment between security controls and business, Evaluate process, and third party viewpoint	Developed framework (Information security governance framework), ISG concept, and ISG definition	Recommended factors	Not specified	Evaluate alignment between security controls and business, Evaluate policies and procedures, and Third party auditing
Hina et al. (2019)	Evaluate policies and procedures, and Evaluate organization security architecture	ISG concept	Recommended factors	Not specified	Evaluate policies and procedures, and Evaluate organization security architecture
Mckissack et al. (2010)	Evaluation controls are aligned with business strategy, evaluates the policies, procedures, and Evaluate organization security architecture	Developed framework (Conceptual model for security assessment), and ISG concept	Recommended factors	Not specified	Evaluate alignment between security controls and business, Evaluate policies and procedures, and Evaluate organization security architecture
Sönmez (2019)	Evaluate organization security architecture	ISG concept	Recommended factors	Not specified	Evaluate organization security architecture

3.3.6. Domain 6: Reporting

In general, reports reflect a clear perception of the results and can improve the decision-making according to the identified priorities in the report. The reports describe the current maturity and compliance with laws and regulations, the organization's principles and policies, and assessment and measurement reports (Nicho, 2018; Ohki et al., 2009). As shown in Table 6, different studies have discussed reporting as one of the CSFs of the ISG components. Reporting is an important aspect available in most of the well-known frameworks and standards especially those related to managing the business in an organization and controlling information security such as BSC, ITIL, COBIT, ISO27k and NIST (De Oliveira et al., 2006; Kusumah et al., 2014; Laksono & Supriyadi, 2016; Mahncke et al., 2009). While others included reports as a component in their developed frameworks (McKissack et al., 2010; Ohki et al., 2009). Reports describe the current organization's maturity toward complying with the laws and regulations, the organization's principles and policies (Nicho, 2018; Ohki et al., 2009). Besides that, reports show the results of the assessment and measurement activities in the organization, which can assist the top management in understanding the return of investment in the organization's protection.

3.3.7. Domain 7: Monitoring

Continuous monitoring is considered as an important factor that enables quick responses to risks, vulnerabilities, and threats that any organization might face in daily life. As shown in Table 7, different studies have discussed the importance of including "monitoring" as a component in an ISG program. Through monitoring, organizations can ensure business continuity, prevent threats, and activate risk response and recovery plans without interruption to the orga-

nization's business (Bobbert & Mulder, 2015; Gashgari et al., 2017; Manjezi & Botha, 2019; Modaresnezhad & Palvia, 2013; Mounia & Bouchaib, 2019). For instance, different studies have suggested using COBIT, ISO27001 to monitor internal controls, systems use, potential threats and an organization's objectives (De Oliveira et al., 2006; Laksono & Supriyadi, 2016; Posthumus & von Solms, 2004; Rubino et al., 2017; Sheikhpour & Modiri, 2012; Shivashankarappa et al., 2012; Stoll et al., 2013). Monitoring can be used for oversighting the behavior of internal users to ensure the critical data and information will not be misused and to maintain the organization's integrity and confidentiality (Corriss, 2010; Hassan & Ismail, 2012; Hina et al., 2019; Jackson & Rahman, 2018; Mishra, 2015; Tan et al., 2010). Potential conflict, changes or risks inside the organization can be managed and detected by monitoring the processes and projects to avoid any impact to the organization's business (Alghamdi et al., 2019; Da Veiga & Eloff, 2007; Haufe et al., 2016; Horne et al., 2017; Kim & Kim, 2015; Manjezi & Botha, 2019; Mounia & Bouchaib, 2019; Ohki et al., 2009; Sönmez, 2019; Vinnakota, 2011; Williams, 2007).

4. Discussion

The analysis of the literature clarified that information security went through different stages and experienced many challenges over the years. These stages and challenges have contributed to emerge ISG as a solution that can assist in alignment between business objectives and information security policies. Nevertheless, ISG is still requiring more support and commitment from the top management as well as a comprehensive framework that can cover all related aspects from governance and information security sides. Besides that, it is

Table 5 – The extracted factors used in developing CSFs related to Measurement domain.

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Ahuja and Chan (2015)	Performance Measurement	Well-known framework (ISO 38500 Principles, COBIT, BSC, and SSE-CMM), and ISG concept	Factors correlated to other factors	Not specified	Performance and process measurement
Bobbert and Mulder (2015)	Lessons learned, Periodic knowledge evaluation, user awareness, and performance and process measurement	ISG concept, and ISG definition	Factors correlated to other factors	Group Support System (GSS) Expert groups	Learned from previous threat, Employee's awareness measurement, and performance and process measurement
Gashgari et al. (2017)	Effective IS awareness and training, and Performance Measurement	Well-known framework (ISO/IEC 27014, 2013, and COBIT 4), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Employee's awareness measurement, and Performance and process measurement
Mishra (2015)	Commitment and culture, Performance and process measurement	ISG concept, and ISG definition	Factors correlated to other factors	Qualitative: interviews	Commitment and culture, and Performance and process measurement
Sheikhpour and Modiri (2012)	User awareness and training, and measure process performance	Well-known framework (ISO/IEC 27001, and COBIT), and ISG concept	Factors correlated to other factors	Not specified	Employee's awareness measurement, and Performance and process measurement
Shivashankarappa et al. (2012)	Information security awareness, education and training, and Performance and process measurement	Well-known framework (COBIT 4.1, PRINCE 2, ITIL V3, and ISO/IEC 27002:2005), and ISG concept	Factors correlated to other factors	Not specified	Employee's awareness measurement, and Performance and process measurement
Vinnakota (2011)	Performance and process measurement	Developed framework (infogov model, and govinfos model), ISG concept, and ISG definition	Factors correlated to other factors	Quantitative: questionnaire, and qualitative tools developed	Performance and process
Oliveira et al. (2006)	Performance and process measurement	Well-known framework (Balanced Scorecard (BSC) - COBIT, and ISO/IEC 17799), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Performance and process measurement
Maynard et al. (2018)	Employee's awareness measurement	Well-known framework (Balanced Scorecard (BSC) - COBIT, and ISO/IEC 17799), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Employee's awareness measurement

(continued on next page)

Table 5 (continued)

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Nicho (2018)	Commitment and culture, and Performance and process measurement	Developed framework (PDCA cycle), ISG concept, and ISG definition	Factors correlated to other factors	Qualitative: expert interviews	Commitment and culture, Performance and process measurement
Rebollo et al. (2011)	Commitment and culture, and Performance and process measurement	ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Commitment and culture, and Performance and process measurement
Shojaie et al. (2015)	Information security awareness, education and training	Well-known framework (ISO27001)	Factors correlated to other factors	Not specified	Employee's awareness measurement
Veiga and Eloff (2007)	User Awareness	Well-known framework (ISO177995, ISO27001, Capability Maturity Model, Information security Architecture (ISA), Protect), and ISG concept	Factors correlated to other factors	Not specified	Employee's awareness measurement
Williams (2007)	Performance and process measurement	Developed framework (Tactical Information Governance Security Model (TIGS)), and ISG concept	Factors correlated to other factors	Pilot study, interviews	Performance and process measurement
Haufe et al. (2016)	Performance evaluation process	Well-known framework (ISO27001, ITIL, COBIT)	Factors correlated to other factors	Pilot implementation	Performance and process measurement
Jackson and Rahman (2018)	Measure performance	Developed framework (Capabilities Alignment with Security Strategy and Execution (CASSE) Platform)	Factors correlated to other factors	Not specified	Performance and process measurement
Modaresnezhad and Palvia (2013)	Employee's awareness, and Performance and processes measurement	ISG concept	Recommended factors	Qualitative: interviews	Employee's awareness, and Performance and process measurement
Alghamdi et al. (2019)	Build reusable repository of threats for requirements, and Performance and process measurement	ISG concept	Factors correlated to other factors	Not specified	Learned from previous threats, and Performance and process measurement
Corriss (2010)	Performance and process measurement	ISG concept	Factors correlated to other factors	Not specified	Performance and process measurement

(continued on next page)

Table 5 (continued)

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Mounia and Bouchaib (2019)	Performance Evaluation, and measure the process and performance	Well-known framework (ISO 38500, ITIL, ISO27001), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Performance and process measurement
Ohki et al. (2009)	Performance and process measurement	Developed framework (Information security governance framework), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Performance and process measurement
Von Solms and von Solms (2006)	Performance and process measurement	Well-known framework (ISO 38500, ITIL, ISO27001), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Performance and process measurement
Von Solms et al. (2011)	Performance and process measurement	Developed framework (A comprehensive Information Security Policy Architecture), and ISG concept	Factors correlated to other factors	Not specified	Performance and process measurement
Hina et al. (2019)	Learned from previous threat, Commitment and culture, and Performance and process measurement	ISG concept	Factors correlated to other factors	Not specified	Learned from previous threat, Commitment and culture, and Performance and process measurement
Hohan et al. (2015)	Performance and process measurement	Developed framework (Self-assessment based on the European Foundation for Quality Management (EFQM) Business Excellence Model)	Factors correlated to other factors	Not specified	Performance and process measurement
Thomson and von Solms (2004)	Awareness	ISG concept	Factors correlated to other factors	Not specified	Employee's awareness measurement
Da Veiga and Martins (2015)	Evaluation of and feedback on the awareness programme, and performance and process measurement	Developed framework (information security culture assessment (ISCA) Model)	Factors correlated to other factors	Quantitative: Survey	Employee's awareness measurement, and performance and process measurement
Ruighaver et al. (2007)	Employee's awareness measurement	ISG concept	Factors correlated to other factors	Not specified	Employee's awareness measurement
Hassan et al. (2012)	Information Security Awareness	Developed framework (Conceptual model), and ISG concept	Factors correlated to other factors	Not specified	Employee's awareness measurement
Mckissack et al. (2010)	Performance and process measurement	Developed framework (Conceptual model), and ISG concept	Factors correlated to other factors	Not specified	Performance and process measurement
Sönmez (2019)	Performance and process measurement	ISG concept	Factors correlated to other factors	Not specified	Performance and process measurement

Table 6 – The extracted factors used in developing CSFs related to Reporting domain.

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Ahuja and Chan (2015)	Audit and IT security reporting problems	Well-known framework (ISO 38500 Principles, COBIT, BSC, and SSE-CMM), and ISG concept	Factors correlated to other factors	Not specified	Assessment report
Bobbert and Mulder (2015)	Regular reporting on security adequacy and effectiveness.	ISG concept, and ISG definition	Factors correlated to other factors	Group Support System (GSS) Expert groups	Assessment report, measurement report, and performance report
Gashgari et al. (2017)	Ensure timely and transparent reporting of IS performance and issues	Well-known framework (ISO/IEC 27014, 2013, and COBIT 4), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Assessment report, measurement report, and performance report
Posthumus and von Solms (2004b)	Assessment report	Developed framework, ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Assessment report
Sheikhpour and Modiri (2012)	Reporting information security events and weaknesses	Well-known framework (ISO/IEC 27001, and COBIT), and ISG concept	Factors correlated to other factors	Not specified	Report, assessment, and measurement report
Oliveira et al. (2006)	Performance report	Well-known framework (Balanced Scorecard (BSC) - COBIT, and ISO/IEC 17799), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Performance report
Horne et al. (2017)	Performance report	ISG concept	Factors correlated to other factors	Not specified	Performance report
Von Solms and von Solms (2004)	Report, assessment, measurement	ISG concept	Factors correlated to other factors	Not specified	Report, assessment, and measurement report
Haufe et al. (2016)	Auditing report	Well-known framework (ISO27001, ITIL, COBIT)	Factors correlated to other factors	Pilot implementation	Assessment report
Manjezi and Botha (2019)	Compliance reports, measurement report, performance	Well-known framework (Direct Control Cycle model), and ISG concept	Factors correlated to other factors	Not specified	Assessment report, measurement report, and performance report
Mounia and Bouchaib (2019)	Reporting, assessment, measurement, and performance	Well-known framework (ISO 38500, ITIL, ISO27001), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Assessment report, measurement report, and performance report
Ohki et al. (2009)	Measurement report	Developed framework (Information security governance framework), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Measurement report
Mckissack et al. (2010)	Assessment report	Developed framework (Conceptual model for security assessment), and ISG concept	Factors correlated to other factors	Not specified	Assessment report
Laksono and Supriyadi (2016)	Assessment report, and Performance report	Well-known framework (COBIT)	Factors correlated to other factors	Not specified	Assessment report, measurement report, and performance report

Table 7 – The extracted factors used in developing CSFs related to Monitoring domain

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Ahuja and Chan (2015)	Monitor Security Posture, Controlling mechanisms and processes	Well-known framework (ISO 38500 Principles, COBIT, BSC, and SSE-CMM), and ISG concept	Factors correlated to other factors	Not specified	Controlling mechanisms and processes
Bobbert and Mulder (2015)	Incident response, Business continuity, Threats and vulnerabilities, Monitoring and managing potential conflicts of interest, Risk controlling mechanisms and processes	ISG concept, and ISG definition	Factors correlated to other factors	Group Support System (GSS) Expert groups	Response to the risk, Business continuity, Threats and vulnerabilities, Monitoring, Potential conflict, and Controlling mechanisms and processes
Gashgari et al. (2017)	Adopt risk based approach, Business continuity, Threats and vulnerabilities, and IT Infrastructure and daily Operation	Well-known framework (ISO/IEC 27014, 2013, and COBIT 4), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Response to the risk, Business continuity, Threats and vulnerabilities, and IT Infrastructure and daily Operation
Mishra (2015)	Business continuity, Controlling mechanisms and processes	ISG concept, and ISG definition	Factors correlated to other factors	Qualitative: interviews	Business continuity, Controlling mechanisms and processes
Patnayakuni and Patnayakuni (2014)	Business continuity, response to risk, Threats and vulnerabilities, continuous process monitoring	Developed framework (conceptual framework), and ISG concept	Factors correlated to other factors	Not specified	Business continuity, response to risk, Threats and vulnerabilities, and Controlling mechanisms and processes
Schinagl and Shahim (2020)	Controlling mechanisms and processes, and IT Infrastructure and daily Operation	ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Controlling mechanisms and processes, and IT Infrastructure and daily Operation
Sheikhpour and Modiri (2012)	Business Continuity Management, Technical vulnerability management, Monitor and evaluate internal control, Acquire and maintain technology infrastructure	well-known framework (ISO/IEC 27001, and COBIT), and ISG concept	Factors correlated to other factors	Not specified	Business continuity, Threats and vulnerabilities, Controlling mechanisms and processes, and IT Infrastructure and daily Operation
Shivashankarappa et al. (2012)	Response selection, Incident escalation, Investigation and diagnosis, Resolution and recovery, Ensure Continuous Service, Control of technical vulnerabilities, and Potential conflict	well-known framework (COBIT 4.1, PRINCE 2, ITIL V3, and ISO/IEC 27002:2005), and ISG concept	Factors correlated to other factors	Not specified	Response to risk, Business continuity, Threats and vulnerabilities, and Potential conflict

(continued on next page)

Table 7 (continued)

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Tan et al. (2017)	Response to risk, Business continuity, Threats and vulnerabilities, Controlling mechanisms and processes, IT Infrastructure and daily Operation	ISG concept	Factors correlated to other factors	Case study	Response to risk, Business continuity, Threats and vulnerabilities, Controlling mechanisms and processes, IT Infrastructure and daily Operation
Vinnakota (2011)	Response to risk, monitor the information security policy of the enterprise	Developed framework (InfoGov model, and GovInfoS model), ISG concept, and ISG definition	Factors correlated to other factors	Quantitative: questionnaire, and qualitative tools developed	Response to risk, and Controlling mechanisms and processes
Oliveira et al. (2006)	Response to the risk, Business continuity, Threats and vulnerabilities, Potential conflict, continually monitor processes,	well-known framework (Balanced Scorecard (BSC) - COBIT, and ISO/IEC 17799), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Response to the risk, Business continuity, Threats and vulnerabilities, Potential conflict, and Controlling mechanisms and processes
Horne et al. (2017)	Business continuity, Threats and vulnerabilities, Potential conflict, Controlling mechanisms and processes, and IT Infrastructure and daily Operation	ISG concept	Factors correlated to other factors	Not specified	Business continuity, Threats and vulnerabilities, Potential conflict, Controlling mechanisms and processes, and IT Infrastructure and daily Operation
Kim and Kim (2015)	Potential conflict, security program performance	Developed framework (Competing values framework), and ISG concept	Factors correlated to other factors	Not specified	Potential conflict, and Controlling mechanisms and processes
Nicho (2018)	Threats and vulnerabilities, and Controlling mechanisms and processes	Developed framework (PDCA cycle), ISG concept, and ISG definition	Factors correlated to other factors	Qualitative: expert interviews	Threats and vulnerabilities, and Controlling mechanisms and processes
Rebollo et al. (2011)	Monitoring, Controlling mechanisms and processes	ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Controlling mechanisms and processes
Rubino et al. (2017)	Monitoring, Controlling mechanisms and processes	well-known framework (COBIT)	Factors correlated to other factors	Not specified	Monitoring, Controlling mechanisms and processes
Saunders and Yu (2011)	Threats and vulnerabilities, Potential conflict, Controlling mechanisms and processes, and IT Infrastructure and daily Operation	ISG concept	Factors correlated to other factors	Not specified	Threats and vulnerabilities, Potential conflict, Controlling mechanisms and processes, and IT Infrastructure and daily Operation
Veiga and Eloff (2007)	Response to risk, Business continuity, Monitoring, Controlling mechanisms and processes	Well-known framework (ISO177995, ISO27001, Capability Maturity Model, Information security Architecture (ISA), Protect), and ISG concept	Factors correlated to other factors	Not specified	Response to risk, Business continuity, Monitoring, Controlling mechanisms and processes

Table 7 (continued)

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Von Solms and von Solms (2004)	Controlling mechanisms and processes	ISG concept	Factors correlated to other factors	Not specified	Monitoring, Controlling mechanisms and processes
Williams (2007)	Identifies the potential threats, and Controlling mechanisms and processes	Developed framework (Tactical Information Governance Security Model (TIGS)), and ISG concept	Factors correlated to other factors	Pilot study, interviews	Threats and vulnerabilities, and Controlling mechanisms and processes
Haufe et al. (2016)	Information security incident management process, Service continuity and availability management process, Threats and vulnerabilities, Potential conflict, Information security risk treatment process, and IT Infrastructure and daily Operation	Well-known framework (ISO27001, ITIL, and COBIT)	Factors correlated to other factors	Pilot implementation	Response to the risk, business continuity, Threats and vulnerabilities, Potential conflict, Controlling mechanisms and processes, IT Infrastructure and daily Operation
Jackson and Rahman (2018)	Monitoring, Controlling mechanisms and processes, IT Infrastructure and daily Operation	Developed framework (Capabilities Alignment with Security Strategy and Execution (CASSE) Platform)	Factors correlated to other factors	Not specified	Controlling mechanisms and processes, and IT Infrastructure and daily Operation
Modaresnezhad and Palvia (2013)	Business continuity, Threats and vulnerabilities, Potential Conflict, Controlling mechanisms and processes, and IT Infrastructure and daily Operation	ISG concept	Factors correlated to other factors	Qualitative: interviews	Business continuity, Threats and vulnerabilities, Potential Conflict, Controlling mechanisms and processes, and IT Infrastructure and daily Operation
Zaydi and Nasserddine (2017)	Controlling mechanisms and processes	Developed framework (Governance, Risk, Compliance and Technology Intelligence GRC-IT), and ISG concept	Factors correlated to other factors	Not specified	Controlling mechanisms and processes
Alghamdi et al. (2019)	Identify threats and vulnerabilities, Potential conflict, and assign security systematic process	ISG concept	Factors correlated to other factors	Not specified	Threats and vulnerabilities, Potential conflict, and Controlling mechanisms and processes
Corriss (2010)	Controlling mechanisms and processes	ISG concept	Factors correlated to other factors	Not specified	Controlling mechanisms and processes
Manjezi and Botha (2019)	Incident Response, Business continuity, Threats and vulnerabilities, Business continuity, and Controlling mechanisms and processes	Well-known framework (Direct Control Cycle model), and ISG concept	Factors correlated to other factors	Not specified	Response to the risk, Business continuity, Threats and vulnerabilities, and Controlling mechanisms and processes

Table 7 (continued)

Studies	Mentioned factors	Derived		Validation	Authors' developed factors
		Explicit	Implicit		
Mounia and Bouchaib (2019)	Business continuity, Controlling mechanisms and processes, and IT Infrastructure and daily Operation	Well-known framework (ISO 38500, ITIL, ISO27001), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Response to the risk, Business continuity, Controlling mechanisms and processes, and IT Infrastructure and daily Operation
Ohki et al. (2009)	Response to the risk, Threats and vulnerabilities, and Controlling mechanisms and processes	Developed framework (Information security governance framework), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Response to the risk, Threats and vulnerabilities, and Controlling mechanisms and processes
Rastogi and von Solms (2004)	Threats and vulnerabilities, and Controlling mechanisms and processes	ISG definition	Factors correlated to other factors	Not specified	Threats and vulnerabilities, and Controlling mechanisms and processes
Tan et al. (2010)	Business continuity, Monitoring, Controlling mechanisms and processes	Developed framework (Security governance framework), and ISG concept	Factors correlated to other factors	Case study	Business continuity, Controlling mechanisms and processes
Von Solms and von Solms (2006)	Controlling mechanisms and processes	Well-known framework (ISO 38500, ITIL, ISO27001), ISG concept, and ISG definition	Factors correlated to other factors	Not specified	Controlling mechanisms and processes
Hina et al. (2019)	Response to the risk, Threats and vulnerabilities	ISG concept	Factors correlated to other factors	Not specified	Response to the risk, and Threats and vulnerabilities
Hohan et al. (2015)	Monitoring processes	Developed framework (Self-assessment based on the European Foundation for Quality Management (EFQM) Business Excellence Model)	Factors correlated to other factors	Not specified	Controlling mechanisms and processes
Hassan et al. (2012)	Controlling mechanisms and processes	Developed framework (Conceptual model), and ISG concept	Factors correlated to other factors	Not specified	Controlling mechanisms and processes
Mckissack et al. (2010)	Threats and vulnerabilities, and Controlling mechanisms and processes	Developed framework (Conceptual model for security assessment), and ISG concept	Factors correlated to other factors	Not specified	Threats and vulnerabilities, and Controlling mechanisms and processes
Sönmez (2019)	Controlling mechanisms and processes	ISG concept	Factors correlated to other factors	Not specified	Controlling mechanisms and processes
Laksono and Supriyadi (2016)	Manage Continuity, and Vulnerability assessments	Well-known framework (COBIT)	Factors correlated to other factors	Not specified	Business continuity, and Threats and vulnerabilities

evident that enabling and implementing ISG requires significant support from the top management in the organization by changing the organizational and information security culture.

Different studies have discussed the importance of integrating corporate governance and culture with the proposed ISG program framework (see [Appendix D](#) and [E](#)). By analyzing these studies, it has found that most of them have not validated the proposed framework or included a detailed description of its procedures and the implementation processes. For instance, some of the studies proposed framework for ISG program without providing details regarding the framework's validation, theoretical approach, or even the methodology that they followed ([Da Veiga & Eloff, 2007](#); [Mahncke et al., 2009](#); [Ohki et al., 2009](#); [Stoll et al., 2013](#); [Tan et al., 2010](#); [Von Solms & Strous, 2002](#)). Other studies (see [Appendix F](#)) recommended well-known frameworks such as COBIT, ISO17799, ISO27001, and ITIL through merging two or more frameworks in order to cover the parts of ISG ([De Oliveira et al., 2006](#); [Gashgari et al., 2017](#); [Manjezi & Botha, 2019](#); [Shivashankarappa et al., 2012](#); [Von Solms, 2005](#)). Most of these studies neither were examined by experts or in real-live context nor provided a guideline for implementing or describing its procedures and processes. While other studies have proposed ISG framework for a particular area, they still have not provided more details regarding the implementation guideline and validation approach. Such as [Patnayakuni and Patnayakuni \(2014\)](#) proposed a conceptual ISG framework based on COBIT and ISO27036 for the value chain without providing information regarding the implementation processes and whether the framework was validated or not.

To the best of our knowledge, the review identified the need for developing a holistic framework for the information security governance that (1) connects the organization's objectives and its protection, (2) addresses each aspect of strategy, control, and regulation, (3) ensures compliance of procedures and guideline with policies, and (4) ensures continuous evaluation and compliance. This finding aligns with the ones mentioned by [Mounia and Bouchaib \(2019\)](#); [Patnayakuni and Patnayakuni \(2014\)](#) that there is no single practical model for ISG. Accordingly, researchers have suggested two or more frameworks to cover governance side and information security side such as ([De Oliveira et al., 2006](#); [Haufe et al., 2016](#); [Kusumah et al., 2014](#); [Manjezi & Botha, 2019](#); [Mounia & Bouchaib, 2019](#); [Nicho, 2018](#); [Sheikhpour & Modiri, 2012](#); [Stoll et al., 2013](#); [Von Solms, 2005](#)). While other researchers have emphasized that ISG framework must be a dynamic for an immediate response and adaptable to emerging changes ([Hohan et al., 2015](#); [Horne et al., 2017](#); [Nicho, 2018](#); [Von Solms, 2001](#); [Williams, 2011](#)). Based on the analysis, we can conclude that developing an ISG framework should consist the following characteristics: meet the organization's requirements, include a guideline for implementation processes, include a description of the responsibilities and accountabilities, risks management, a measurement mechanism, and be clear and easy to use.

For an effective ISG framework, this review has identified seven domains and 34 CSFs (see [Appendix A](#), [B](#), and [C](#)). However, it has been found that some of the CSFs can be combined in terms of (1) their roles and objectives to avoid overlapping with similar factors, and (2) to minimize the organization's

effort in implementing the ISG framework. Therefore, [Fig. 3](#) shows the 27 CSFs divided into seven domains after combining factors with similar objectives and traits. In the "Responsibility and Accountability" domain, the CSFs "Define Roles and Ownerships", "Risks Ownerships", and "Employees Roles" have the same objectives and role as they focus on defining the responsibilities and accountabilities of managers and employees in organizations. Besides that, in these factors, the ownership of systems can be defined, so each administration will be responsible and accountable for their systems and determine the risk level that can be taken. Based on that, it is suggested that the "Define Roles and Ownerships", "Risks Ownerships", and "Employees Roles" factors can be combined and become "Define Roles and Risks Ownerships". In the "Define Roles and Risks Ownerships" the roles and responsibilities for each administration and employee will define and determine the ownership of the risk between management in the organization.

From the risk control perspective, the factor "Administration Critical Business" can be inserted under "Risk Management" to avoid overlapping in roles and responsibilities. The "Risk Management" factor can determine (1) risks appetite policy with the business owners, (2) define the critical businesses, and (3) identify the process of managing the risk. Regarding the support of the ISG program, information security policies, procedures and obtain top management support in organizations; it is suggested that the "Support ISG Program", "Top management and Stakeholders support", and "Alignment between Business and Security" factors can be merged to become the "Information Security Governance Committee". The "Information Security Governance Committee" can define (1) the responsibilities and accountabilities to the ISG program, and (2) explain the support mechanism and continued alignment between the organization's objectives and information security policies and procedures.

Measuring the security awareness program and its efficiency, and the top management and internal users' commitment toward the organization's policies and procedures are very important. The awareness measurement is considered as an indicator for the management which reflects the maturity level, managers and employees' support, and identifies if the internal users have learned from previous threats and attacks. Based on that, it is suggested that the factor "Employees Awareness" and "Commitment and Culture" can be combined based on their objectives and become "Awareness Maturity". The "Awareness Maturity" factor can measure (1) the awareness level toward the organization's principles, (2) security controls, and (3) the commitment of each administration's responsibilities and roles toward information security policies and procedures. Furthermore, preventing information security threats requires a proactive and rapid response to the risks to protect the organization's information and assets. Therefore, in the "Monitoring" domain, it is suggested that "Response to the Risk" and "Threats and vulnerabilities" factors be combined and become "Incident Management". The "Incident Management" factor can detect different types of threats through proactive action and rapid response to the risk. This can be achieved through continuous monitoring and performing proactive security checks to discover threats and vulnerabilities.

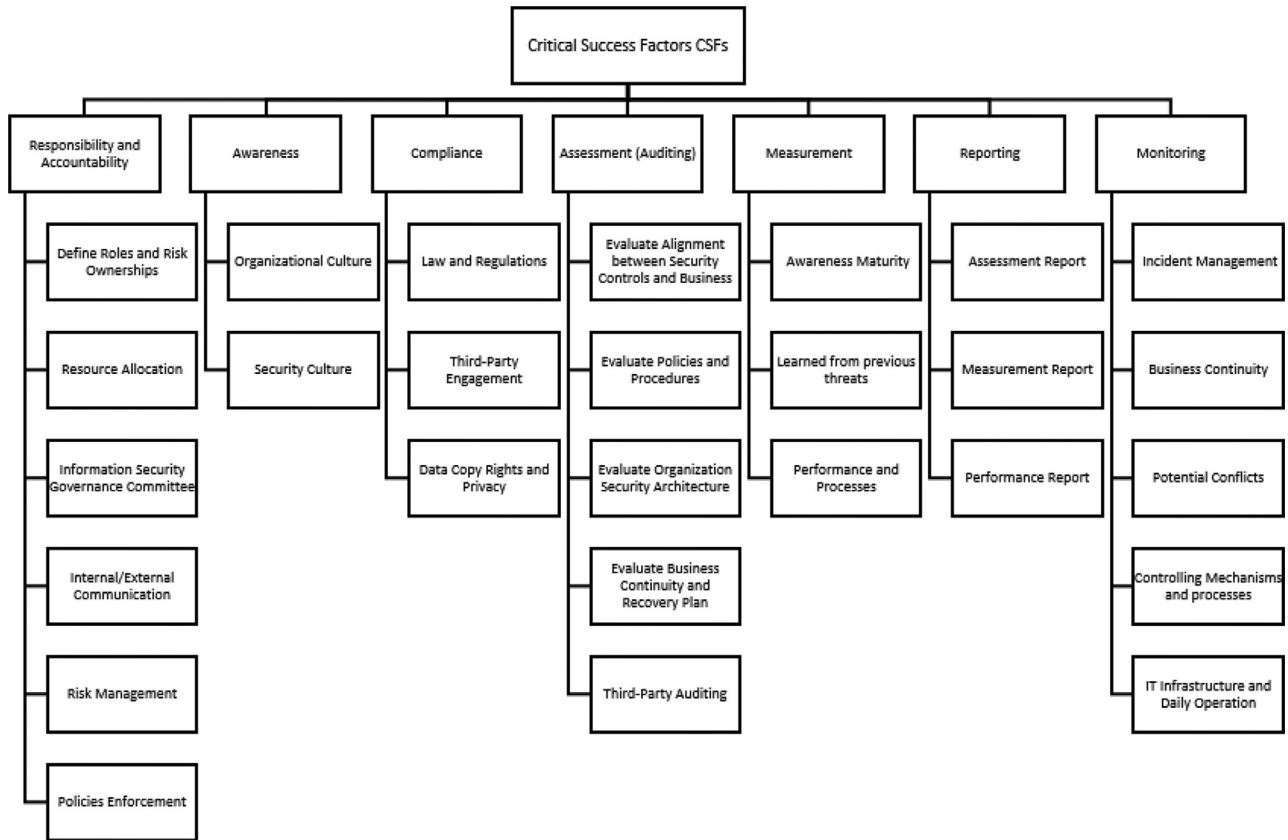


Fig. 3 – Merged CSFs based on similarity and traits.

5. Practical implication

The identified ISG domains and the CSFs (i.e. seven Domains and 27 CSFs) can be utilized for further analysis as a foundation for developing a comprehensive ISG framework. This will encourage organizations to adopt ISG program that will assist them in achieving their objectives and protection of their information and assets.

6. Limitations

The presented literature review has several limitations. The ISG domains and CSFs have been identified through qualitative content analysis and based on authors' interpretations for the findings which may produce bias into the review. Further, our review is focused on ISG and strategy in the internal environment of the organization rather than technology-focused. Despite these limitations, the review's findings emerged the main requirements that organizations should pay attention for the successful establishment of the ISG program.

7. Conclusion

The conducted literature review has revealed the need for a comprehensive ISG framework that contributes to fulfilling the organization's objectives and its protection. The framework should be flexible, dynamic, and adaptable to business

changes and meet the organization's requirements. The review has also shown the importance of top management engagement to take their responsibility toward providing the required support for ISG programs. Moreover, the review has identified the significance of organizational and security culture that should consider through establishing an awareness program as a part of an ISG framework.

The review has identified 27 CSFs divided into seven domains that may be utilized as a basis for developing the ISG framework. These ISG domains and CSFs are crucial and beneficial to the development of information security governance as a comprehensive solution for establishing alignment between information security policies and the organization's objectives. These factors can contribute toward gaining the support of top management and engaging all organization parties following a "Top-Down" approach. As a result, this will motivate the employees to take their responsibility toward achieving the organization's objectives and its protection. Future work will focus on applying the review's results to demonstrate the strength of the identified ISG domains and CSFs to utilize them in developing a comprehensive ISG framework.

Declaration of Competing Interest

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Appendixes

Appendix A – The CSFs related to Responsibility and Accountability Domain

Authors	Domain 1: Responsibility and Accountability Critical Success Factors CSFs										
	DRO-1	ACB	DRO-2	ER	RA	SISGP	TMSS	ABSB	IEC	RM	PE
Antoniou (2018)	✓	■	■	✓	■	✓	✓	✓	✓	✓	✓
Bobbert and Mulder (2015)	✓	■	✓	✓	■	✓	✓	✓	✓	✓	✓
Coertze and Von Solms (2013)	■	■	■	■	■	✓	✓	■	■	■	✓
Corriss (2010)	■	■	■	■	■	✓	✓	■	■	■	✓
Da Veiga and Martins (2015)	■	■	■	■	■	■	✓	■	✓	■	✓
Gashgari et al. (2017)	✓	✓	■	✓	✓	✓	✓	✓	✓	✓	✓
Hassan et al. (2012)	■	■	■	■	■	■	■	■	■	■	■
Haufe et al. (2016)	■	■	■	■	✓	✓	■	✓	✓	✓	■
Hina et al. (2019)	■	■	■	■	■	■	✓	■	✓	■	✓
Hohan et al. (2015)	■	■	■	■	■	■	✓	✓	■	■	■
Horne et al. (2017)	■	■	■	✓	■	✓	✓	✓	✓	✓	✓
Jackson and Rahman (2018)	■	■	■	■	✓	✓	■	✓	■	✓	■
Kim and Kim (2015)	■	■	■	✓	■	✓	✓	■	✓	■	■
Kusumah et al. (2014)	■	■	■	■	■	■	■	■	■	■	■
Laksono and Supriyadi (2016)	■	■	■	■	■	✓	■	■	■	■	■
Lourinho et al. (2017)	■	■	■	■	■	■	■	■	■	■	■
Ma et al. (2009)	■	■	■	■	■	■	■	■	■	■	■
Mahncke and Williams 2014	■	■	■	■	■	■	■	■	■	■	■
Mahncke et al. (2009)	■	■	■	■	■	■	■	■	■	■	■
Maynard et al. (2018)	■	■	■	✓	■	✓	✓	■	■	■	✓
McKissack et al. 2010	■	■	■	■	■	■	■	■	■	■	■
Mishra (2015)	✓	■	✓	✓	✓	✓	✓	✓	✓	■	✓
Nicho (2018)	■	■	■	✓	■	✓	■	✓	■	✓	✓
Ohki et al. (2009)	■	■	■	■	■	✓	✓	■	✓	✓	■
Oliveira et al. (2006)	■	✓	■	✓	■	✓	✓	✓	✓	✓	✓
Posthumus and von Solms (2004b)	✓	■	■	■	■	✓	✓	■	✓	✓	✓
Rastogi and von Solms (2004)	■	■	■	■	■	✓	✓	✓	■	■	■
Rebollo et al. (2011)	■	■	■	✓	■	✓	✓	✓	■	✓	✓
Rubino et al. (2017)	■	■	■	✓	✓	■	✓	■	✓	✓	✓
Ruighaver et al. (2007)	■	■	■	✓	■	■	■	■	■	■	✓
Saunders and Yu (2011)	■	■	■	✓	✓	✓	✓	■	■	■	✓
Sheikhpour and Modiri (2012)	✓	✓	✓	✓	✓	■	■	✓	✓	✓	✓
Shivashankarappa et al. (2012)	✓	✓	✓	✓	✓	■	■	✓	✓	✓	✓
Shojaie et al. (2015)	■	■	■	✓	✓	■	■	■	■	■	✓
Shojaie et al. (2015)	■	■	■	■	■	■	■	■	■	■	■
Siregar et al. (2017)	■	■	■	■	■	■	■	■	■	■	■
Soyref and Seltsika (2014)	■	■	■	■	■	■	■	■	■	■	■
Tan et al. (2010)	■	■	■	■	■	✓	■	■	■	■	✓
Thomson and von Solms (2004)	■	■	■	■	■	○	✓	■	■	■	✓
Thomson and von Solms (2005)	■	■	■	✓	■	✓	✓	■	■	■	✓
Veiga and Eloff (2007)	■	■	■	✓	■	✓	✓	■	■	■	✓
Vinnakota (2011)	✓	■	■	✓	■	✓	✓	■	✓	■	✓
von Solms (2005)	■	■	■	■	■	■	■	■	■	■	■
von Solms and Strous (2002)	■	■	■	■	■	✓	✓	■	■	■	■
von Solms and von Solms (2004)	■	■	■	✓	■	✓	✓	■	■	■	✓
von Solms and von Solms (2006)	■	■	■	■	■	✓	✓	■	■	■	✓
von Solms et al. (2011)	■	■	■	■	■	✓	✓	✓	■	■	✓
Williams (2007)	✓	■	■	✓	■	■	■	■	■	■	✓
Williams (2011)	■	■	■	■	■	■	■	■	■	■	■
Zaydi and Nasserddine (2017)	■	■	■	■	✓	■	■	✓	■	✓	■
Zia (2015)	■	■	■	■	■	■	■	■	■	■	■
Mounia and Bouchaib (2019)	■	■	■	■	■	✓	■	✓	■	✓	✓
Alghamdi et al. (2019)	■	■	■	■	■	■	✓	✓	■	■	■

(continued on next page)

Appendix A (continued)

Authors	Domain 1: Responsibility and Accountability Critical Success Factors CSFs										
	DRO-1	ACB	DRO-2	ER	RA	SISGP	TMSS	ABSB	IEC	RM	PE
Manjezi and Botha (2019)	■	■	■	■	■	✓	■	■	■	■	■
Sönmez (2019)	■	■	■	■	■	■	■	■	■	■	■
Schinagl and Shahim (2020)	✓	■	✓	✓	✓	✓	✓	✓	✓	✓	■
Tan et al. (2017)	✓	■	✓	✓	✓	■	✓	■	✓	✓	■
Ahuja and Chan (2015)	✓	■	■	■	✓	■	■	✓	■	✓	■
Patnayakuni and Patnayakuni (2014)	✓	■	✓	✓	■	■	✓	■	✓	✓	✓
Modaresnezhad and Palvia (2013)	■	■	■	■	✓	✓	✓	✓	✓	■	✓

Define Roles and ownerships=DRO-1, Administration critical business=ACB, Define risk ownerships=DRO-2, Employee's Roles=ER, Resource allocation=RA, Support information security governance program=SISGP, Top management and stakeholders support=TMSS, Alignment between Security and Business=ABSB, Internal/External Communication=IEC, Risk management=RM, and Policies enforcement= PE

Appendix B – The CSFs related to Awareness, Compliance and Assessment Domains

Authors	Domain2: Awareness Domain3: Compliance Domain 4: Assessment (Auditing)									
	Critical Success Factors CSFs									
	OC	SC	LR	TPE	DCP	EABSCB	EPP	EOSA	EBCRP	TPA
Antoniou (2018)	■	■	✓	✓	✓	■	■	■	■	■
Bobbert and Mulder (2015)	✓	✓	✓	■	■	■	✓	✓	✓	✓
Coertze and Von Solms (2013)	■	■	✓	■	■	■	■	■	■	■
Corriss (2010)	✓	✓	✓	■	■	✓	✓	■	■	✓
Da Veiga and Martins (2015)	■	✓	✓	■	■	■	■	■	■	■
Gashgari et al. (2017)	■	✓	✓	■	✓	✓	✓	✓	✓	■
Hassan et al. (2012)	■	✓	■	■	■	■	■	■	■	■
Haufe et al. (2016)	■	✓	■	✓	■	✓	✓	■	■	✓
Hina et al. (2019)	■	✓	✓	✓	✓	■	✓	✓	■	■
Hohan et al. (2015)	✓	✓	✓	■	■	■	■	■	■	■
Horne et al. (2017)	■	■	✓	✓	■	■	■	■	■	■
Jackson and Rahman (2018)	■	■	■	■	■	✓	■	■	■	■
Kim and Kim (2015)	■	■	■	■	■	■	■	■	■	■
Kusumah et al. (2014)	■	■	■	■	■	■	■	■	■	■
Laksono and Supriyadi (2016)	■	■	■	■	■	■	■	■	■	■
Lourinho et al. (2017)	■	■	■	■	■	■	■	■	■	■
Ma et al. (2009)	■	■	■	■	■	■	■	■	■	■
Mahncke and Williams 2014	■	■	■	■	■	■	■	■	■	■
Mahncke et al. (2009)	■	■	■	■	■	■	■	■	■	■
Maynard et al. (2018)	■	■	■	■	■	■	■	■	■	■
McKissack et al. 2010	■	✓	✓	■	■	✓	✓	✓	■	■
Mishra (2015)	■	✓	✓	■	✓	✓	✓	✓	■	✓
Nicho (2018)	■	✓	✓	■	■	✓	✓	✓	■	✓
Ohki et al. (2009)	■	■	■	■	■	✓	✓	■	■	✓
Oliveira et al. (2006)	✓	■	■	■	■	✓	✓	■	■	■
Posthumus and von Solms (2004b)	■	■	■	■	■	■	✓	■	■	■
Rastogi and von Solms (2004)	■	■	✓	■	■	■	■	■	■	■
Rebollo et al. (2011)	■	✓	✓	■	■	■	■	■	■	■
Rubino et al. (2017)	■	■	■	■	■	■	■	■	■	■
Ruighaver et al. (2007)	■	✓	■	■	■	■	■	■	■	■
Saunders and Yu (2011)	■	✓	■	■	■	■	✓	■	■	■
Sheikhpour and Modiri (2012)	■	■	✓	■	■	■	■	■	■	■
Shivashankarappa et al. (2012)	■	■	✓	■	✓	■	✓	■	■	■
Shojaie et al. (2015)	■	✓	■	■	■	■	■	■	■	■
Shojaie et al. (2015)	■	■	■	■	■	■	■	■	■	■
Siregar et al. (2017)	■	■	✓	■	■	■	■	■	■	■

(continued on next page)

Appendix B (continued)

Authors	Domian2: Awareness		Domain3: Compliance			Domain 4: Assessment (Auditing)				
	Critical Success Factors CSFs									
	OC	SC	LR	TPE	DCP	EABSCB	EPP	EOSA	EBCRP	TPA
Soyref and Seltsika (2014)	■	■	■	■	■	■	■	■	■	■
Tan et al. (2010)	■	✓	■	■	■	■	■	■	■	■
Thomson and von Solms (2004)	■	■	■	■	■	■	■	■	■	■
Thomson and von Solms (2005)	✓	✓	■	■	■	■	■	■	■	■
Veiga and Eloff (2007)	■	✓	✓	■	■	■	■	■	■	■
Vinnakota (2011)	✓	✓	✓	■	✓	✓	✓	■	■	■
von Solms (2005)	■	■	■	■	■	■	■	■	■	■
von Solms and Strous (2002)	■	■	■	■	■	■	■	■	■	■
von Solms and von Solms (2004)	■	■	■	■	■	■	■	■	■	■
von Solms and von Solms (2006)	■	■	■	■	■	■	■	■	■	■
von Solms et al. (2011)	■	■	■	■	■	■	■	■	■	■
Williams (2007)	✓	✓	■	■	■	■	✓	■	■	✓
Williams (2011)	■	✓	■	■	■	■	■	■	■	■
Zaydi and Nasserddine (2017)	■	■	✓	■	■	✓	■	■	■	■
Zia (2015)	■	■	■	■	■	■	■	■	■	■
Mounia and Bouchaib (2019)	■	■	✓	■	■	✓	✓	■	■	■
Alghamdi et al. (2019)	✓	✓	✓	✓	✓	✓	✓	✓	■	■
Manjezi and Botha (2019)	■	■	■	■	■	■	■	■	✓	■
Sönmez (2019)	■	■	■	■	■	■	■	✓	■	■
Schinagl and Shahim (2020)	✓	✓	✓	■	■	■	■	■	■	■
Tan et al. (2017)	■	■	✓	■	■	■	✓	✓	✓	■
Ahuja and Chan (2015)	■	■	✓	■	■	■	✓	■	■	■
Patnayakuni and Patnayakuni (2014)	■	■	✓	■	■	■	✓	✓	✓	✓
Modaresnezhad and Palvia (2013)	✓	✓	✓	■	✓	■	✓	✓	■	✓

Organizational culture=OC, Security culture=SC, Law and regulatory=LR, Third-party engagement=TPE, Data copyrights and privacy=DCP, Evaluate alignment between security controls and business=EABSCB, Evaluate policies and procedure=EPP, Evaluate organization security architecture=EOSA, Evaluate business continuity and recover plan=EBCRP, Third-party auditing=TPA

Appendix C – The CSFs related to Awareness, Compliance and Assessment Domains

Authors	Domain 5: Measurement				Domain 6: Reporting			Domain 7: Monitoring					
	Critical Success Factors CSFs												
	EA	LFPT	CC	PP	AP	MP	PR	RTR	BC	TV	PC	CMP	ITIDP
Antoniou (2018)	■	■	■	■	■	■	■	■	■	■	■	■	■
Bobbert and Mulder (2015)	✓	✓	■	✓	✓	✓	✓	✓	✓	✓	✓	✓	■
Coertze and Von Solms (2013)	■	■	■	■	■	■	■	■	■	■	■	■	■
Corriss (2010)	✓	■	✓	✓	■	■	■	■	■	■	■	✓	■
Da Veiga and Martins (2015)	✓	■	✓	✓	■	■	■	■	■	■	■	■	■
Gashgari et al. (2017)	✓	■	■	✓	✓	✓	✓	✓	✓	✓	■	■	✓
Hassan et al. (2012)	✓	■	■	■	■	■	■	■	■	■	■	✓	■
Haufe et al. (2016)	✓	■	■	✓	✓	■	✓	✓	✓	✓	✓	✓	✓
Hina et al. (2019)	✓	✓	✓	✓	■	■	■	✓	■	✓	■	■	■
Hohan et al. (2015)	■	■	■	✓	■	■	■	■	■	■	■	✓	■
Horne et al. (2017)	■	■	■	■	■	■	✓	■	✓	✓	✓	✓	✓
Jackson and Rahman (2018)	■	■	■	✓	■	■	■	■	■	■	■	✓	✓
Kim and Kim (2015)	■	■	■	■	■	■	■	■	■	■	✓	✓	■
Kusumah et al. (2014)	■	■	■	■	■	■	■	■	■	■	■	■	■
Laksono and Supriyadi (2016)	■	■	■	■	✓	■	✓	■	✓	✓	■	■	■
Lourinho et al. (2017)	■	■	■	■	■	■	■	■	■	■	■	■	■
Ma et al. (2009)	■	■	■	■	■	■	■	■	■	■	■	■	■
Mahncke and Williams 2014	■	■	■	■	■	■	■	■	■	■	■	■	■

(continued on next page)

Appendix C (continued)

Authors	Domain 5: Measurement				Domain 6: Reporting			Domain 7: Monitoring					
	Critical Success Factors CSFs				AP	MP	PR	RTR	BC	TV	PC	CMP	ITIDP
	EA	LFPT	CC	PP									
Mahncke et al. (2009)	■	■	■	■	■	■	■	■	■	■	■	■	■
Maynard et al. (2018)	✓	■	■	■	■	■	■	■	■	■	■	■	■
McKissack et al. 2010	✓	■	■	✓	✓	■	■	■	■	✓	■	✓	■
Mishra (2015)	✓	■	✓	✓	■	■	■	■	✓	■	■	✓	■
Nicho (2018)	✓	■	✓	✓	✓	■	■	■	■	✓	■	✓	■
Ohki et al. (2009)	■	■	■	✓	■	✓	■	✓	■	✓	■	✓	■
Oliveira et al. (2006)	✓	■	■	✓	■	■	✓	✓	✓	✓	✓	✓	■
Posthumus and von Solms (2004b)	■	■	■	■	✓	■	■	■	■	■	■	■	■
Rastogi and von Solms (2004)	■	■	■	■	■	■	✓	✓	■	✓	■	✓	■
Rebollo et al. (2011)	■	■	✓	✓	■	■	■	■	■	■	■	✓	■
Rubino et al. (2017)	■	■	■	■	■	■	■	■	■	■	■	✓	■
Ruighaver et al. (2007)	✓	■	■	■	■	■	■	■	■	■	■	■	■
Saunders and Yu (2011)	■	■	■	■	■	■	■	■	■	✓	✓	✓	✓
Sheikhpour and Modiri (2012)	✓	■	■	✓	✓	✓	■	■	✓	✓	■	✓	✓
Shivashankarappa et al. (2012)	✓	■	■	✓	■	■	■	✓	✓	✓	✓	✓	✓
Shojaie et al. (2015)	✓	■	■	■	■	■	■	■	■	■	■	■	■
Shojaie et al. (2015)	■	■	■	■	■	■	■	■	■	■	■	■	■
Siregar et al. (2017)	■	■	■	■	■	■	■	■	■	■	■	■	■
Soyref and Seltsika (2014)	■	■	■	■	■	■	■	■	■	■	■	■	■
Tan et al. (2010)	■	■	■	■	■	■	■	■	✓	■	■	✓	■
Thomson and von Solms (2004)	✓	■	■	■	■	■	■	■	■	■	■	■	■
Thomson and von Solms (2005)	■	■	■	■	■	■	■	■	■	■	■	■	■
Veiga and Eloff (2007)	✓	■	■	■	■	■	■	✓	✓	■	■	✓	■
Vinnakota (2011)	✓	■	■	✓	■	■	■	✓	■	■	■	✓	■
von Solms (2005)	■	■	■	■	■	■	■	■	■	■	■	■	■
von Solms and Strous (2002)	■	■	■	■	■	■	■	■	■	■	■	■	■
von Solms and von Solms (2004)	■	■	■	■	✓	✓	■	■	■	■	■	✓	■
von Solms and von Solms (2006)	■	■	■	✓	■	■	■	■	■	■	■	✓	■
von Solms et al. (2011)	■	■	■	✓	■	■	■	■	■	■	■	■	■
Williams (2007)	✓	■	■	✓	■	■	■	■	■	✓	■	✓	■
Williams (2011)	■	■	■	■	■	■	■	■	■	■	■	■	■
Zaydi and Nasserddine (2017)	■	■	■	■	■	■	■	■	■	■	■	✓	■
Zia (2015)	■	■	■	■	■	■	■	■	■	■	■	■	■
Mounia and Bouchaib (2019)	■	■	■	✓	✓	✓	✓	✓	✓	■	■	✓	✓
Alghamdi et al. (2019)	■	✓	■	✓	■	■	■	■	■	✓	✓	✓	■
Manjezi and Botha (2019)	■	■	■	✓	✓	✓	✓	✓	✓	✓	✓	✓	■
Sönmez (2019)	■	■	■	✓	■	■	■	■	■	■	■	✓	■
Schinagl and Shahim (2020)	■	■	■	■	■	■	■	■	■	■	■	■	■
Tan et al. (2017)	■	■	■	■	■	■	■	✓	✓	✓	✓	✓	✓
Ahuja and Chan (2015)	■	■	■	✓	✓	■	✓	■	■	■	■	✓	■
Patnayakuni and Patnayakuni (2014)	■	■	■	■	■	■	■	✓	■	✓	■	✓	■
Modaresnezhad and Palvia (2013)	✓	■	■	✓	■	■	■	✓	✓	✓	✓	✓	✓

Employee's awareness=EA, Learned from previous threats=LFPT, Commitment and culture=CC, Performance and processes=PP, Assessment report=AP, Measurement report=MP, Performance report=PR, Response to the risk=RTR, Business continuity=BC, Threats and vulnerabilities=TV, Potential conflict=PC, Controlling mechanisms and processes=CMP, and IT Infrastructure and daily Operation=ITIDP

Appendix D – Studies mentioned corporate governance and proposed ISG framework.

Study	Corporate Governance	Framework	Examined	Guideline for implementation	Description of the procedures	Comments
von Solms and Strous (2002)	Yes	No	-	-	-	Reviewed several frameworks
Posthumus and von Solms (2004)	Yes	Governance and Management	No	No	No	-
von Solms (2005)	Yes	Mapped between COBIT2000v3 and ISO17799:2000	No	No	No	-

(continued on next page)

Appendix D (continued)

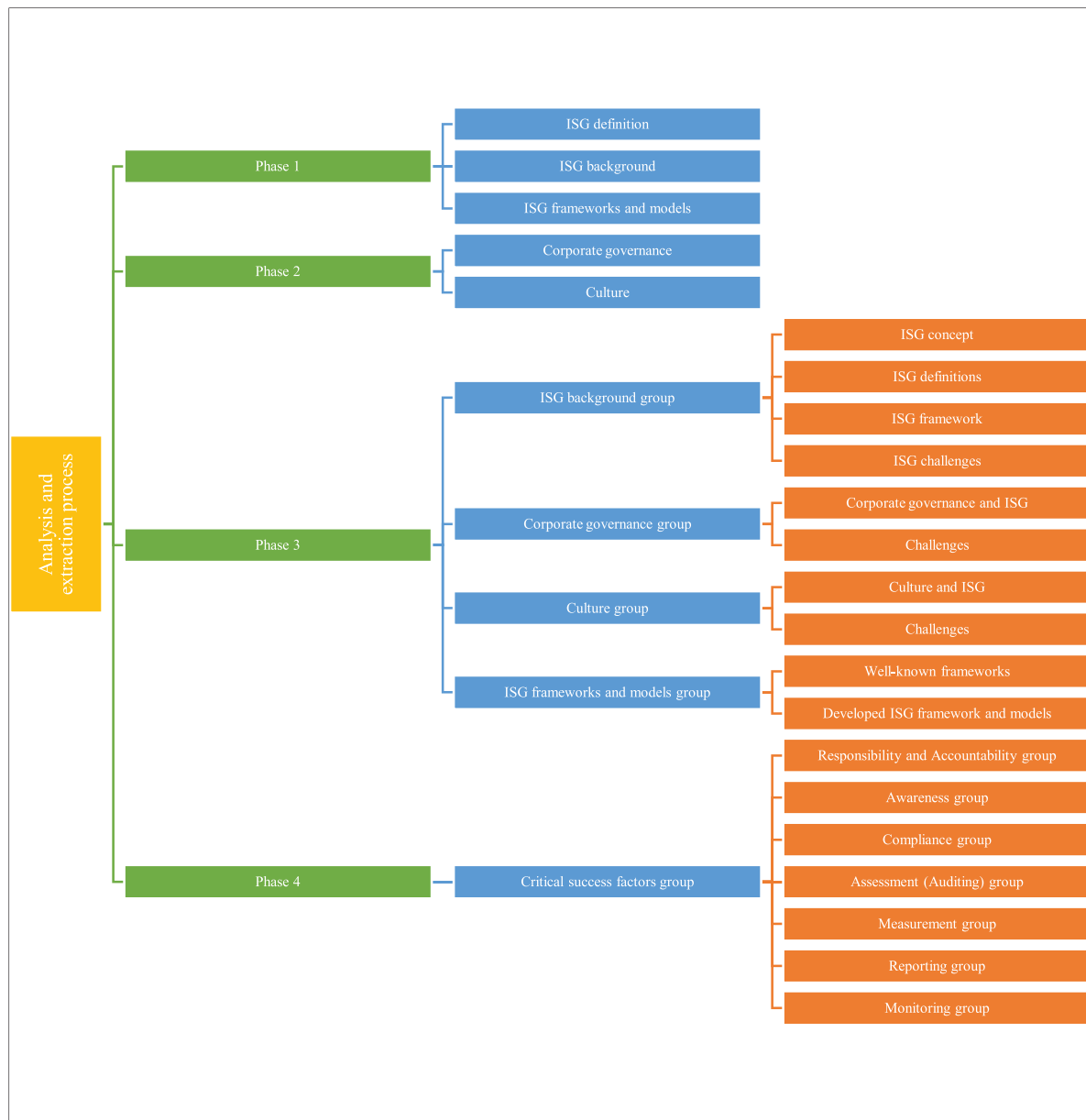
Study	Corporate Governance	Framework	Examined	Guideline for implementation	Description of the procedures	Comments
Oliveira et al. (2006)	Yes	BSC, COBIT2000v3, No ISO/IEC 17799:2000 and CobiT Maturity Model		Yes	No	The guideline showed the activities according to the responsibilities
Ohki et al. (2009)	Yes	Direct, Monitor, Evaluate, Report and Oversee	No	No	No	-
Mahncke et al. (2009)	Yes	No	-	-	-	Reviewed several frameworks
Sajko et al. (2011)	Yes	COBIT4.1 and ISO27002	No	No	No	-
Shivashankarappa et al. (2012)	Yes	Mapped COBIT4.1, No Prince2, ITILv3 and ISO 27002:2005	No	No	No	-
Fazlida and Said (2015)	Yes	No	-	-	-	Highlights the suitability of using ISO 27001 and COBIT for ISG
Antoniou (2018)	Yes	Based on Posthumus and Solms (2004)	Yes	No	No	Small pilot study
Gashgari et al. (2017)	Yes	Mapped COBIT5, ISO27014:2013, CSFs and Essentials domains of ISG	No	No	No	-

Appendix E – Studies mentioned culture and proposed ISG framework.

Study	Culture	Framework	Examined	Guideline for implementation	Description of the procedures	Comments
Broderick (2006)	Yes	Mapped COBIT to ISO-27001:2005 Governance and Management	No	No	No	-
Posthumus and von Solms (2004)	Yes	Mapped Capability Maturity Model by (McCarthy & Campbell 2001), ISO17799:2005, PROTECT by (Eloff & Eloff 2005) and Information Security Architecture by (Tudor 2000)	No	No	No	-
De Vegia and Eloff (2007)	Yes	Mapped Capability Maturity Model by (McCarthy & Campbell 2001), ISO17799:2005, PROTECT by (Eloff & Eloff 2005) and Information Security Architecture by (Tudor 2000)	No	No	No	-
Tan et al. (2010)	Yes	Developed ISG framework	Just examined one aspect	No	No	Case study
Stoll et al. (2013)	Yes	Proposed COBIT, ITIL and ISO2700x	No	No	No	-
Nicho (2018)	Yes	Proposed PDCA Cycle, ISO27K and NIST	No	No	No	Interview

Appendix F – Summarise for the studies that recommended well-known frameworks for ISG.

[illegible]



Appendix G – Shows the analysis and extraction process.

CRedit authorship contribution statement

Sultan AlGhamdi: Conceptualization, Methodology, Validation, Formal analysis, Data curation, Writing - original draft, Writing - review & editing. **Khin Than Win:** Conceptualization, Methodology, Validation, Formal analysis, Data curation, Writing - original draft, Writing - review & editing, Supervision. **Elena Vlahu-Gjorgievska:** Conceptualization, Methodology, Validation, Formal analysis, Data curation, Writing - original draft, Writing - review & editing, Supervision.

REFERENCES

- Ahuja S, Chan YE. IT security governance: a framework based on ISO 38500. *Proceedings of the CONF-IRM 2015*, 2015.
- Al-Izki F, Weir GR. Management attitudes toward information security in Omani public sector organisations. *Proceedings of the 2016 Cybersecurity and Cyberforensics Conference (CCC)*, 2016.
- Alghamdi F, Hamza N, Tamimi M. Factors that Influence the Adoption of Information Security on Requirement Phase for Custom-Made Software at SMEs. *Proceedings of the 2019 2nd International Conference on Computer Applications & Information Security (ICCAIS)*, 2019.
- Allen J. *Governing for Enterprise Security* (CMU/SEI-2005-TN-023). Retrieved January 18, 2020, from the Software Engineering Institute, Carnegie Mellon University. Website; 2005 <http://resources.sei.cmu.edu/library/asset-view.cfm?AssetID=7453>.
- Allen J, Westby J. *Governing for Enterprise Security (GES) Implementation Guide*. USA: Carnegie Mellon University, Software Engineering Institute, CERT; 2007.
- Antoniou G. A Framework for the Governance of Information Security: Can it be Used in an Organization, 2018. *SoutheastCon*; 2018.
- Bobbett Y, Mulder H. Governance practices and critical success factors suitable for business information security. *Proceedings of the 2015 International Conference on Computational Intelligence and Communication Networks (CICN)*, 2015.
- Coertze J, Von Solms R. A model for information security governance in developing countries. In: *E-Infrastructure and E-Services for Developing Countries*, 119; 2013. p. 279–88.
- Corriss L. Information security governance: Integrating security into the organizational culture. *Proceedings of the 2010 Workshop on Governance of Technology, Information and Policies*, 2010.
- Creswell J. *Research Design: Qualitative, Quantitative, and Mixed Methods Approaches*. 4th ed. SAGE Publications; 2014.
- Da Veiga A, Eloff J. An information security governance framework. *Inf. Syst. Manag.* 2007;24(4):361–72. doi:10.1080/10580530701586136.
- Da Veiga A, Martins N. Improving the information security culture through monitoring and implementation actions illustrated through a case study. *Comput. Secur.* 2015;49:162–76.
- De Oliveira G, Carmo La, Almeida A. Enterprise security governance; a practical guide to implement and control information security governance (ISG). *Proceedings of the 2006 IEEE/IFIP Business Driven IT Management*, 2006.
- Elachgar H, Regragui B. Information security, new approach. *Proceedings of the Second International Conference on the Innovative Computing Technology (INTECH 2012)*, 2012.
- Gashgari G, Walters RJ, Wills G. A proposed best-practice framework for information security governance. *Proceedings of the IoTBDS*, 2017.
- Hassan NH, Ismail Z. A conceptual model for investigating factors influencing information security culture in healthcare environment, 65; 2012. p. 1007–12. doi:10.1016/j.sbspro.2012.11.234.
- Haufe K, Colomo-Palacios R, Dzombeta S, Brandis K, Stantchev V. A process framework for information security management [Article]. *IJISPM-Int. J. Inf. Syst. Proj. Manag.* 2016;4(4):27–47. doi:10.12821/ijispm040402.
- Hina S, Selvam D, Panneer D, Lowry P. Institutional governance and protection motivation: theoretical insights into shaping employees' security compliance behavior in higher education institutions in the developing world. *Comput. Secur.* 2019;87.
- Hohan A, Olaru M, Pirnea I. Assessment and continuous improvement of information security based on TQM and business excellence principles, 32; 2015. p. 352–9. doi:10.1016/S2212-5671(15)01404-5.
- Horne C, Maynard S, Ahmad A. Organisational information security strategy: review, discussion and future research. *Australas. J. Inf. Syst.* 2017;21:1–17. doi:10.3127/ajis.v21i0.1427.
- Jackson G, Rahman S. Security governance, management and strategic alignment via capabilities. *Proceedings of the 2017 International Conference on Computational Science and Computational Intelligence (CSCI)*, 2018.
- Johnston A, Hale R. Improved security through information security governance. *Commun. ACM* 2009;52(1):126–9. doi:10.1145/1435417.1435446.
- Khoo B, Harris P, Hartman S. Information security governance of enterprise information systems: an approach to legislative compliant. *Int. J. Manag. Inf. Syst. (IJMIS)* 2010;14(3).
- Kim K, Kim J. A role of information security committee based on competing values framework. *Proceedings of the 17th International Conference on Electronic Commerce 2015*, 2015.
- Kusumah P, Sutikno S, Rosmansyah Y. Model design of information security governance assessment with collaborative integration of COBIT 5 and ITIL (case study: INTRAC). *Proceedings of the 2014 International Conference on ICT For Smart Society (ICISS)*, 2014.
- Laksono H, Supriyadi Y. Design and implementation information security governance using Analytic Network Process and cobit 5 for Information Security a case study of unit XYZ. *Proceedings of the 2015 International Conference on Information Technology Systems and Innovation (ICITSI)*, 2016.
- Lidster W, Rahman S. Obstacles to implementation of information security governance. *Proceedings of the 17th IEEE International Conference On Trust, Security And Privacy In Computing And Communications/12th IEEE International Conference On Big Data Science And Engineering*, 2018.
- Lourinho R, Almeida R, Da Silva M, Pinto P, Barafort B. Mapping of enterprise governance of IT practices metamodells. In: *Information Systems*, 299; 2017. p. 492–505. doi:10.1007/978-3-319-65930-5_39.
- Mahncke R, Williams P. Developing and validating a healthcare information security governance framework. *Electron. J. Health Inform.* 2014;8(2):1–13.
- Mahncke RJ, McDermid DC, Williams PA. *Measuring information security governance within general medical practice*. Perth, Western Australia; 2009.
- Manjezi Z, Botha RA. From concept to practice: untangling the direct-control cycle. *Proceedings of the Ninth International Conference on Information Communication and Management*, 2019.
- Maynard S, Tan T, Ahmad A, Ruighaver T. Towards a framework for strategic security context in information security governance. *Pac. Asia J. Assoc. Inf. Syst.* 2018;10(4):65–88. doi:10.17705/1pais.10403.

- McKissack J, Hooper V, Hope B. An organisational model for information security assessment. *Proceedings of the International Conference on Information Management and Evaluation*, 2010.
- Mishra S. Information security governance and internal audits: a processual model. *Proceedings of the 2007 Southern Association for Information Systems Conference*, 2007.
- Mishra S. Organizational objectives for information security governance: a value focused assessment. *Inf. Comput. Secur.* 2015;23(2):122–44. doi:[10.1108/Ics-02-2014-0016](https://doi.org/10.1108/Ics-02-2014-0016).
- Modaresnezhad, M., & Palvia, P. (2013). The Efficacy of IS Privacy and Security Governance Structures. *The 19th Americas Conference on Information Systems (AMCIS) 2013 Proceedings*.
- Moulton R, Coles RS. Applying information security governance. *Comput. Secur.* 2003;22(7):580–4. doi:[10.1016/S0167-4048\(03\)00705-3](https://doi.org/10.1016/S0167-4048(03)00705-3).
- Mounia Z, Bouchaib N. A new comprehensive solution to handle information security Governance in organizations. *Proceedings of the 2nd International Conference on Networking, Information Systems & Security*, 2019.
- Munira RA, Molok NNA, Talib S. Exploring the factors influencing top management involvement and participation in information security. *Proceedings of the PACIS*, 2017.
- Musa N. A conceptual framework of IT security governance and internal controls. *Proceedings of the 2018 Cyber Resilience Conference (CRC)*, 2018.
- Nicho M. A process model for implementing information systems security governance. *Inf. Comput. Secur.* 2018;26(1):10–38. doi:[10.1108/Ics-07-2016-0061](https://doi.org/10.1108/Ics-07-2016-0061).
- Ohki E, Harada Y, Kawaguchi S, Shiozaki T, Kagawa T. Information security governance framework. *Proceedings of the first ACM workshop on Information security governance*, 2009.
- Patnayakuni R, Patnayakuni N. Information security in value chains: a governance perspective. *Proceedings of the 20th Americas Conference on Information Systems*, 2014.
- Posthumus S, Von Solms R. A framework for the governance of information security. *Comput. Secur.* 2004a;23(8):638–46. doi:[10.1016/j.cose.2004.10.006](https://doi.org/10.1016/j.cose.2004.10.006).
- Posthumus S, von Solms R. A responsibility framework for information security. *Proceedings of the Working Conference on Integrity and Internal Control in Information Systems*, 2004b.
- Rao S, Ramachandran S. Information security governance arrangements: The devil is in the details. *Proceedings of the AMCIS 2007*, 2007.
- Rastogi R, von Solms R. Information security governance-a re-definition. *Proceedings of the Working Conference on Integrity and Internal Control in Information Systems*, 2004.
- Rebollo O, Mellado D, Sánchez LE, Fernández-Medina E. Comparative analysis of information security governance frameworks: a public sector approach. *Proceedings of the 11th European Conference on eGovernment-ECEG*, 2011.
- Rubino M, Vitolla F, Garzoni A. The impact of an IT governance framework on the internal control environment. *Rec. Manag. J.* 2017;27(1):19–41. doi:[10.1108/Rmj-03-2016-0007](https://doi.org/10.1108/Rmj-03-2016-0007).
- Ruighaver A, Maynard S, Chang S. Organisational security culture: Extending the end-user perspective. *Comput. Secur.* 2007;26(1):56–62. doi:[10.1016/j.cose.2006.10.008](https://doi.org/10.1016/j.cose.2006.10.008).
- Sajko M, Hadjina N, Sedinić I. Information security governance and how to accomplish it. *Proceedings of the 2011 Proceedings of the 34th International Convention MIPRO*, 2011.
- Schinagl, S., & Shahim, A. (2020). What do we know about information security governance? "From the basement to the boardroom": towards digital security governance. *10.1108/ics-02-2019-0033*
- Sheikhpour R, Modiri N. An approach to map COBIT processes to ISO/IEC 27001 information security management controls. *Int. J. Secur. Appl.* 2012;6(2):13–28.
- Shivashankarappa A, Smalov L, Dharmalingam R, Anbazhagan N. Implementing it governance using COBIT: A case study focusing on critical success factors. *Proceedings of the World Congress on Internet Security (WorldCIS-2012)*, 2012.
- Sönmez FÖ. A conceptual model for a metric based framework for the monitoring of information security tasks' efficiency. *Procedia Comput. Sci.* 2019;160:181–8.
- Steinbart P, Raschke R, Gal G, Dilla W. The influence of a good relationship between the internal audit and information security functions on information security outcomes. *Account. Organ. Soc.* 2018;71:15–29. doi:[10.1016/j.aos.2018.04.005](https://doi.org/10.1016/j.aos.2018.04.005).
- Stoll M, Felderer M, Breu R. In: *Emerging Trends in Computing, Informatics, Systems Sciences, and Engineering*. Information management for holistic, collaborative information security management. New York, NY; 2013.
- Tan T, Ruighaver A, Ahmad A. Information Security Governance: When Compliance Becomes More Important than Security. In: *Security and Privacy - Silver Linings in the Cloud*, 330. Springer; 2010. p. 55–67.
- Tan TH, Maynard SB, Ahmad A, Ruighaver T. Information security governance: a case study of the strategic context of information security. *Proceedings of the PACIS*, 2017.
- Thomson K, Von Solms R. Information security obedience: a definition. *Comput. Secur.* 2005;24(1):69–75. doi:[10.1016/j.cose.2004.10.005](https://doi.org/10.1016/j.cose.2004.10.005).
- Tu Z, Yuan Y. Critical success factors analysis on effective information security management: a literature review. *Proceedings of the 20th Americas Conference on Information Systems*, 2014.
- Vinnakota T. Systems approach to information security governance: an imperative need for sustainability of enterprises. In: *Proceedings of the 2011 Annual IEEE India Conference*. IEEE; 2011. p. 1–8.
- Von Solms B. Corporate governance and information security. *Comput. Secur.* 2001;20(3):215–18.
- Von Solms B. Information Security governance: COBIT or ISO 17799 or both? *Comput. Secur.* 2005;24(2):99–104. doi:[10.1016/j.cose.2005.02.002](https://doi.org/10.1016/j.cose.2005.02.002).
- Von Solms B, Von Solms R. The 10 deadly sins of information security management. *Comput. Secur.* 2004;23(5):371–6.
- Von Solms K, Strous L. Information security: a corporate governance issue. *Proceedings of the Working Conference on Integrity and Internal Control in Information Systems*, 2002.
- Von Solms R, Thomson K-L, Maninjwa P. Information security governance control through comprehensive policy architectures. *Proceedings of the 2011 Information Security for South Africa*, 2011.
- Von Solms R, Von Solms SH. Information security governance: a model based on the direct-control cycle. *Comput. Secur.* 2006;25(6):408–12. doi:[10.1016/j.cose.2006.07.005](https://doi.org/10.1016/j.cose.2006.07.005).
- Whitman M, Mattord H J. Information security governance for the non-security business executive. *J. Executive Educ.* 2014;11(1):97–111.
- Williams N. The importance of governance and culture on strategic information security. *Proceedings of the 17th IBIMA conference on Creating Global Competitive Economies: A 360-degree Approach*, 2011.
- Williams P. Information governance: a model for security in medical practice. *J. Digit. Forensics Secur. Law* 2007;2(1):57–73.
- Wu Y, Saunders C. Governing information security: governance domains and decision rights allocation patterns. *Inf. Resour. Manag. J.* 2011;24(1):28–45. doi:[10.4018/irmj.2011010103](https://doi.org/10.4018/irmj.2011010103).

Zaydi M, Nasserddine B. Information system security governance: Technology intelligence perspective. *Proceedings of the 2016 International Conference on Advanced Communication Systems and Information Security (ACOSIS)*, 2017.

Sultan AlGhamdi is a PhD student in Professor in School of Computing and Information Technology at the University of Wollongong. He is founder and chairman of Cybersecurity for Children Association in Saudi Arabia. He has over 17-year experience in the IT field between teaching and management since 2003. He worked as Operation and Information Security Manager in the government sector in Saudi Arabia. He was responsible for different projects related to infrastructure and information security. He received various appreciation certificates related to different achievements and developed solutions. His research interest is in information security governance and strategies.

Khin Than Win (MBBS, DCS, MSc. PhD) is an Associate Professor in School of Computing and Information Technology at the University of Wollongong. Her research interest is in information systems

in healthcare, persuasive technology, health data analytics and information security. She has received major research funding such as National Health and Medical Research Council Idea Grant, Australian Research Council (ARC) Discovery and ARC linkage grants. She has published in high impact journals and major conferences in information systems, persuasive technology and health informatics.

Elena Vlahu-Gjorgievska received her PhD from the Faculty of Computer Science and Engineering at the "Ss. Cyril and Methodius" University in Skopje, in 2013. Currently, she is a lecturer in the School of Computing and Information Technology at the University of Wollongong, Australia. Her research interests include information systems, persuasive technology and e-health. Elena has published her work in a number of high-ranked journals and conference proceedings.